

Monitorización y Auditoría de Seguridad

Práctica 4 - Presencial

1. Objetivo

Esta práctica está basada en la monitorización y auditoría de seguridad en sistemas. La primera parte de la práctica estará basada en el uso de software dedicado para realizar la monitorización de redes de computadores. En concreto se hará uso de la **máquina virtual de prácticas** para trabajar con *Wireshark* y *Nmap*. La segunda parte de esta práctica estará basada en la auditoría de seguridad que ofrece Windows 11.

2. Wireshark

Wireshark es un software analizador de protocolos utilizado para monitorear, analizar y solucionar problemas en redes de comunicaciones. Es considerado como un “*sniffer*” (“olisqueador”) ya que puede analizar y monitorear el tráfico que transcurre a través de una red (cableada o inalámbrica).

Inicialmente, con herramientas de este tipo era muy fácil obtener información relevante de una red, como por ejemplo, las conversaciones que tenía la gente a través de aplicaciones de chat como WhatsApp. Actualmente se ha cifrado la comunicación entre emisor y receptor y por tanto ya no tenemos accesible esta información.

En esta sección de la práctica y como primera aproximación a este tipo de software, se analiza el intercambio de paquetes entre el servidor web y el cliente web (navegador web) realizado en la práctica anterior. Para ello, accede a la web de descarga del software:

<https://www.wireshark.org/download.html>

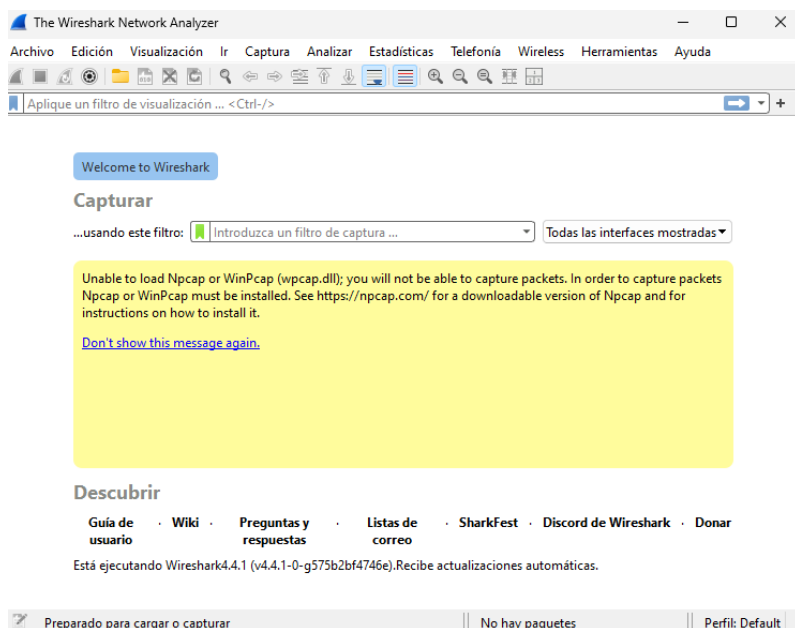
Descarga y usa la versión portable para Windows x64 **en la Máquina Virtual de prácticas**:



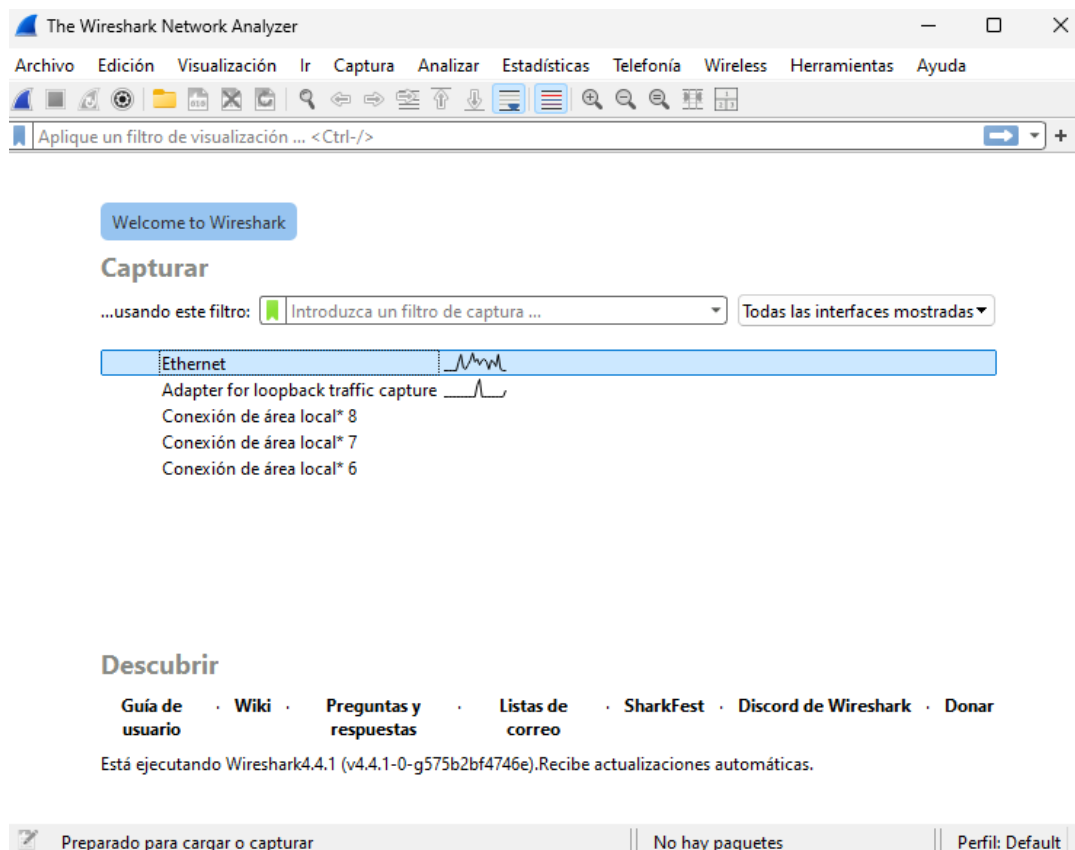
Para capturar paquetes de las interfaces de red, Wireshark necesita el driver de red **Npcap**, que se debe descargar de su página web e instalar en la MV:

<https://npcap.com/>

Con esto conseguimos que el software pueda atender a las diferentes interfaces de red y hacer escaneos completos de ellas. Si no lo hacemos, en el arranque de Wireshark nos aparecerá la siguiente pantalla:



Procede a realizar la instalación de Npcap y vuelve a arrancar Wireshark para observar su interfaz:



Pulsa el primer botón por la izquierda (aleta de tiburón azul) para iniciar una captura.

Pulsa el segundo botón por la izquierda (cuadro rojo) para parar la captura.

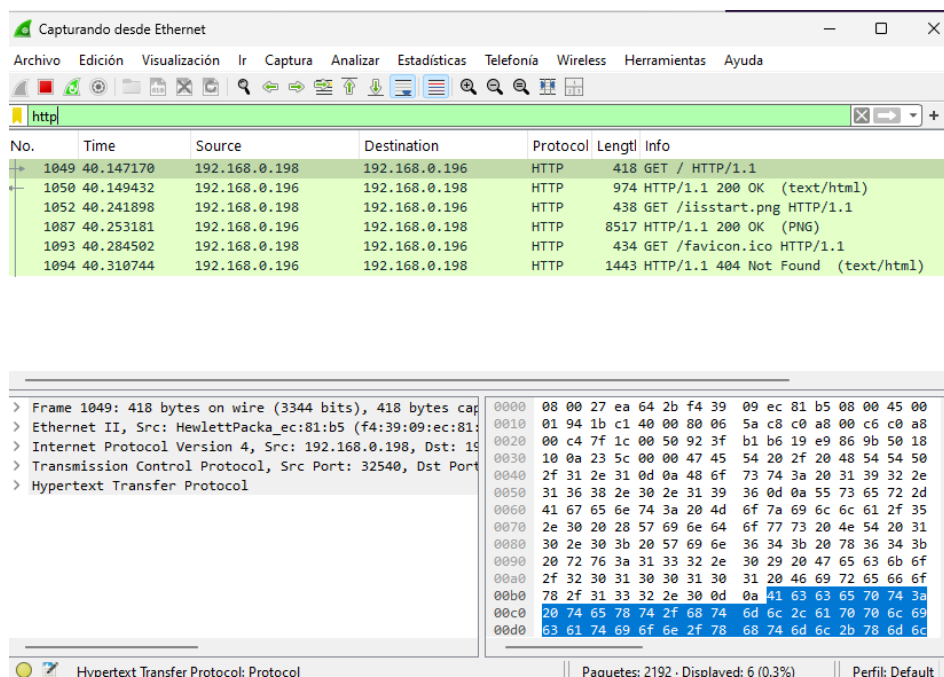
En pocos segundos se pueden capturar miles de paquetes, sin generar tráfico deliberadamente usando aplicaciones, para evitar esto, deberemos desarrollar filtros de captura de paquetes.

Descarta los paquetes capturados que se muestran en la interfaz.

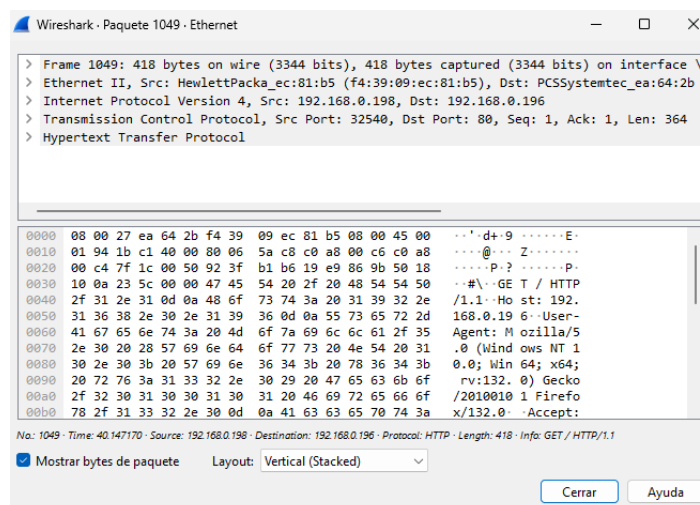
Selecciona la interfaz de red que esté conectada y capturando tráfico de la red. En el caso de la figura superior será "Ethernet".

DESARROLLO DE UN FILTRO DE PAQUETES Y VISUALIZACIÓN DE INFORMACIÓN RELACIONADA

El filtro es una línea que se introduce en el cuadro para el filtro en la interfaz de Wireshark que se muestra en la figura previa. Pulsa el botón verde en el extremo izquierdo del cuadro. Verás que puedes seleccionar uno de los filtros predefinidos disponibles, por ejemplo el denominado “http” que buscará comunicaciones mediante este protocolo. Si arrancas la captura con este filtro es probable que se capturen pocos paquetes o incluso ninguno. Para ver cómo captura paquetes de la red. Desde la máquina anfitriona, realiza una visita a la web por defecto desplegada en prácticas anteriores en el IIS. Recuerda que esta web está desplegada haciendo uso del protocolo HTTP que usa una conexión TCP en el puerto 80. Al entrar verás como Wireshark captura el tráfico que está viajando por la red en ese sentido:



Como puedes ver, se obtienen todos los paquetes transmitidos en relación de la fuente (IP de máquina anfitriona) al destino (IP máquina servidor – virtual). Si haces click en alguno de los mensajes transmitidos puedes ver la información extendida del mismo, pudiendo acceder a las diferentes partes del mismo:



Verifica la información que puedes encontrar en cada uno de los apartados que nos ofrece el paquete para determinar la posible información a obtener. No hace falta que hagas una revisión exhaustiva, pero sí que determines qué se puede llegar a obtener con esta captura de tráfico de red.

Elimina el filtro pulsando el botón rojo en el extremo derecho del cuadro y para la captura de paquetes de red.

Un filtro de captura genérico tiene el formato de una secuencia de primitivas conectadas por las conjunciones “and o or” y opcionalmente precedidas por “not”.

[not] primitiva [and|or [not] primitiva ...]

Ejemplo: tcp.port == 80

Este filtro captura todo el tráfico tcp con el puerto 80 (http), que realizará algo parecido a la anterior búsqueda.

Las posibilidades que nos ofrecen las búsquedas pueden ser las siguientes:

[tcp|udp] [src|dst] **port** <port>

Esta primitiva permite filtrar por números de puerto. Usar tcp o udp para indicar el tipo de protocolo a considerar para el puerto indicado. Si no se usan se capturan paquetes para ambos protocolos. Usar src o dst para capturar solo los paquetes en los aparece el puerto indicado como origen o como destino.

[src|dst] **host** <host_IP/name>

Esta primitiva permite filtrar por la dirección IP o nombre de un host. Usando src solo se capturan los paquetes en los que la dirección IP aparece como origen y usando dst solo se capturan los paquetes en los que la dirección IP aparece como destino. Si no se especifica src o dst los paquetes en los que aparece la dirección IP, bien como origen o como destino, son capturados.

Como **ejercicio**, desarrolla **un filtro adecuado que permita ver el tráfico entre el servidor web seguro y un navegador web** que teníamos en prácticas anteriores, pero atendiendo al protocolo https (puerto 443), intenta minimizar el número de paquetes capturado que no corresponden al tráfico de interés.

Una vez introducido y probado el filtro conviene guardarlo en un fichero, procede a ello.

ANÁLISIS DE PAQUETES CAPTURADOS

Atendiendo a las conexiones realizadas haciendo uso de la comunicación segura entre cliente (navegador en máquina anfitriona) y servidor seguro (servidor web en la máquina virtual), mantén el filtro que filtraba tráfico HTTPS e intenta responder a las siguientes preguntas:

- ¿Puedes localizar ClientHello?
- ¿Qué versión de TLS se está utilizando?
- ¿Le sigue ServerHello?
- ¿Hay otros mensajes “lógicos” del protocolo TLS que han sido integrados en el mismo paquete TCP con el mensaje ServerHello?
- ¿Detectas luego el mensaje ClientKeyExchange?
- ¿Hay más mensajes del cliente integrados en el mismo paquete TCP?
- ¿Aparece finalmente el mensaje ChangeCipherSpec que envía el servidor?

Para realizar esta parte correctamente, el servidor y el cliente deben poder establecer una conexión correcta, sino habrá paquetes de los mencionados que no se puedan ver ya que no se establece conexión y no se envían/reciben todos los mensajes.

CAPTURA DE CONTRASEÑA CON USO DE WIRESHARK

Wireshark, nos permite visualizar gran parte de los paquetes que viajan por la red, por lo que, si viajan paquetes en texto plano, podremos interceptarlos de forma casi automática e intuitiva.

En esta sección se presenta cómo es posible capturar una contraseña de acceso a un Router, ya que la configuración de seguridad que tiene es muy elemental, ya que hace uso del método POST enviando la información en texto plano.

En primer lugar, definiremos el filtro necesario para ver qué paquetes viajan por la red haciendo uso del método POST en HTTP: ***http.request.method=="POST"***. No olvides que debemos aplicar el filtro para que únicamente capture los paquetes que lo cumplen.

Si pongo a funcionar Wireshark, veré que no se envía ningún mensaje (o muy pocos) hasta que se realice un *request* de este tipo a través de mi navegador.

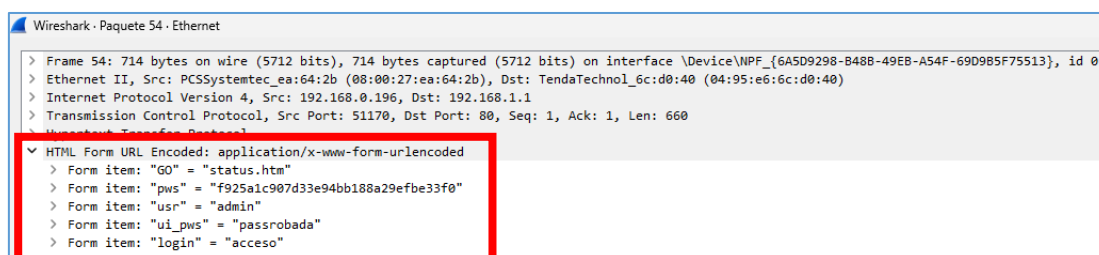
A continuación, desde un navegador accedo a la pantalla de mi Router y establezco un usuario y contraseña:



Al enviar el formulario de ingreso en la pantalla de administración, el tráfico se captura por Wireshark pudiendo observar lo siguiente:

*Ethernet						
Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda						
http.request.method=="POST"						
No.	Time	Source	Destination	Protocol	Length	Info
54	16.979438	192.168.0.196	192.168.1.1	HTTP	714	POST /login.cgi HTTP/1.1 (application/x-www-form-urlencoded)

Wireshark ha detectado un paquete (el 54 en mi caso) desde la fuente que fue accedido (máquina virtual en mi caso) con destino a la IP del Router. Ya que intenté autenticarme contra la página que puedes visualizar más arriba. Al inspeccionar el elemento (doble click), podemos observar los campos que tiene dicho paquete viendo que en el último, podemos acceder a la password en texto plano, así como al usuario por lo que podre hacer uso de ella para acceder y modificar el router sin problema.



3. Nmap

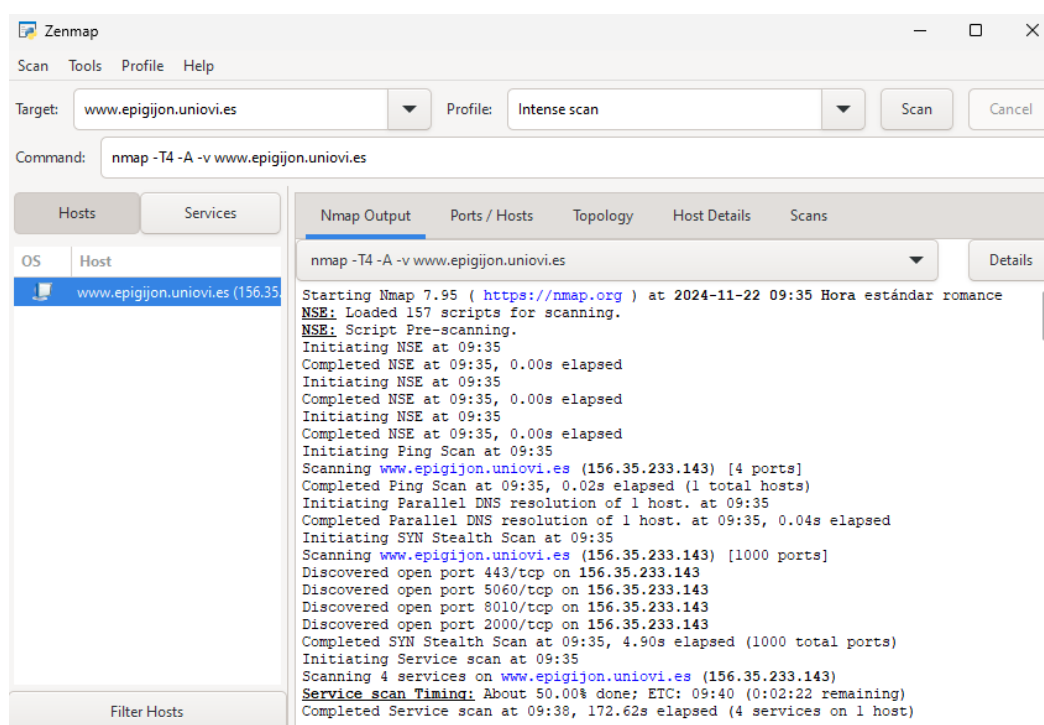
Nmap es un programa de código abierto que permite realizar escaneo de puertos. Aunque originalmente fue creado para Linux, en la actualidad es multiplataforma, usándose para evaluar la seguridad de sistemas informáticos, así como para descubrir servicios o servidores en una red. Para ello, el software envía paquetes definidos a otros equipos y analiza las respuestas.

Accede a la página web de Nmap para descargar el instalador de la herramienta, descarga e instala la última versión **estable** del software ya que este incorpora todo lo necesario para llevar a cabo esta práctica: <https://nmap.org/download.html>

Instala la herramienta y su interfaz gráfica, **Zenmap**, en la **máquina virtual** usada para prácticas.

Para una ayuda online detallada usar: <https://nmap.org/book/zenmap.html>

Al arrancar Zenmap, aparece la ventana siguiente, en la que se ha seleccionado un nombre de host en el campo "Objetivo" (Target) y se ha pulsado el botón "Escaneo" (Scan) para comprobar el correcto funcionamiento. Este escaneo puede tardar un poco (varios minutos) deja que se realice de forma completa y revisa los mensajes en el "Nmap Output".



La **elección del objetivo** (target) a escanear incluye nombres de hosts, que debe resolver el DNS y también, direcciones IP específicas como 156.35.33.105. También se puede escanear una subred completa, como 156.35.141.0/24. Observar cómo se utiliza el sufijo /24 para indicar la máscara de subred. Esta notación se denomina CIDR (*Classless Inter-Domain Routing*). También se pueden usar direcciones como 156.35.141-145.*. El * se usa como un comodín que representa todo el rango válido que va de 0 a 255.

Zenmap recuerda los objetivos escaneados recientemente. Para volver a realizar un escaneo previo, despliega los escaneos recientes pulsando el botón flecha abajo del campo "Objetivo" (Target) y selecciona al escaneo previo deseado.

Nmap es una herramienta diseñada para utilizarse en modo comando. Zenmap es tan solo una interfaz gráfica de Nmap y existen otras interfaces alternativas.

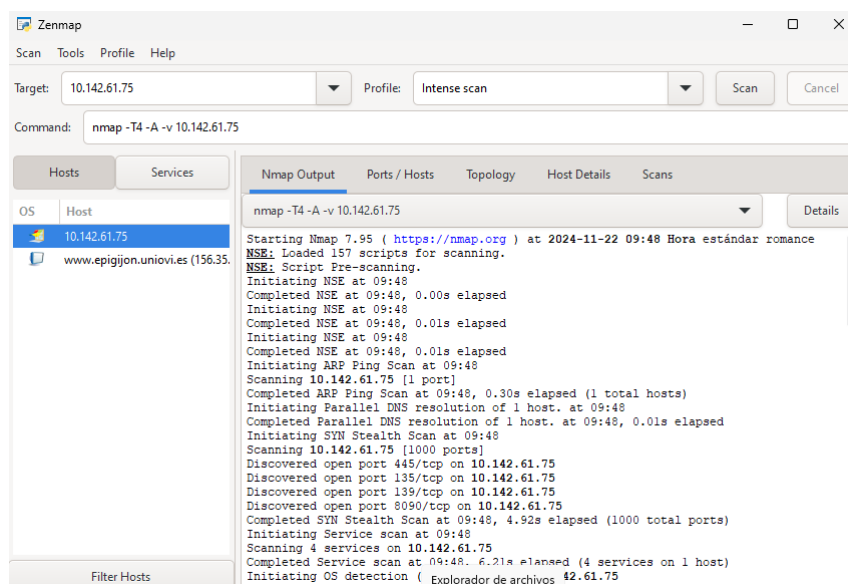
Zenmap siempre muestra el comando Nmap que se genera en base a las opciones seleccionadas en la interfaz gráfica. En la figura anterior el comando es: `nmap -T4 -A -v www.epigijon.uniovi.es`

La **elección del perfil** de escaneo también es importante. Por defecto Zenmap ofrece el perfil "Intense scan", que se traduce a la opción `-A` en el comando Nmap. Este perfil realiza un análisis intensivo para descubrir los equipos que hay en una red y analizarlos. Si hay muchos equipos empleará mucho tiempo.

Si tan solo se desea saber **que equipos hay en una red** se puede usar un perfil más simple, por ejemplo "Ping scan".

Es posible editar perfiles y almacenarlos para realizar un escaneo adaptado a unas determinadas necesidades. También es posible editar directamente el comando Nmap para realizar un escaneo específico. En este caso el campo "Perfil" (Profile) se pone en blanco, para indicar que no se está utilizando ningún perfil predeterminado.

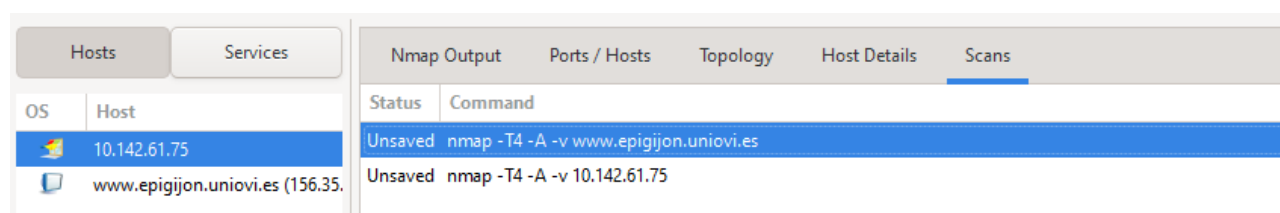
El concepto de **inventario de red** es una característica importante de Zenmap. Cuando ha terminado un escaneo, se puede iniciar otro en la misma ventana de Zenmap. Los resultados del segundo escaneo se añaden a los del primero. Podremos realizar escaneos a otros host de la red. Mira la IP de tu máquina anfitriona y realiza un escaneo hacia ella sin modificar los parámetros. Deja que concluya el escaneo (puede tardar un poco) y observa el resultado.



Observar que en el panel izquierdo aparece el nuevo host escaneado. Observar también que Nmap ha identificado su sistema operativo, cuyo icono aparecen a la izquierda de su nombre (Windows).

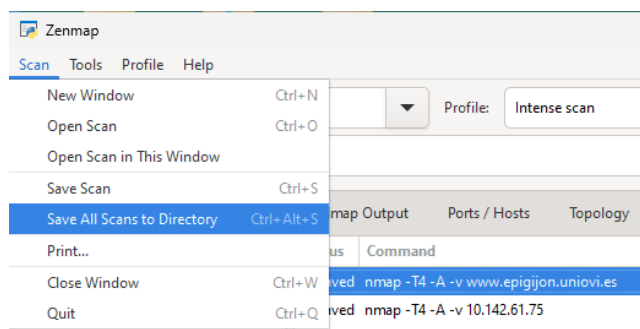
En el panel derecho está seleccionada la ficha "Salida Nmap" (Nmap output). Debajo de la ficha hay un campo para la selección del comando de escaneo. Hay que seleccionar específicamente cada escaneo para ver sus resultados.

La ficha "Escaneos" (Scans) contiene un listado de los escaneos realizados, tal como muestra la figura siguiente. Observar que su estado es "Sin guardar" (Unsaved), pues aún no se han guardado en disco.

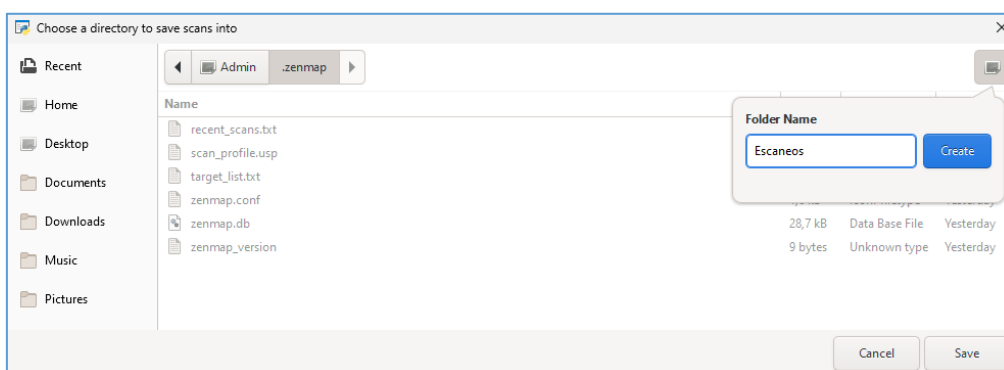


La colección de escaneos que se agregan en una misma vista o ventana de Zenmap, se denomina un inventario de red.

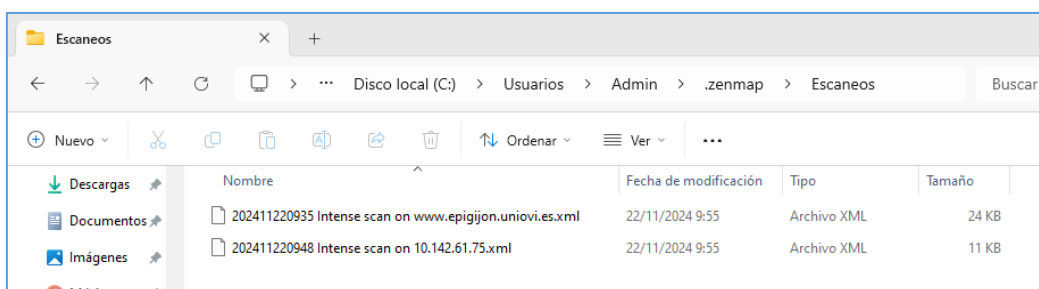
Para **guardar un inventario en disco** hay que seleccionar el menú "Escaneo" (Scan) de la barra de menús de Zenmap, y seleccionar la opción "Guardar todos los escaneos en un Directorio" (Save All Scans to Directory), tal como muestra la figura siguiente:



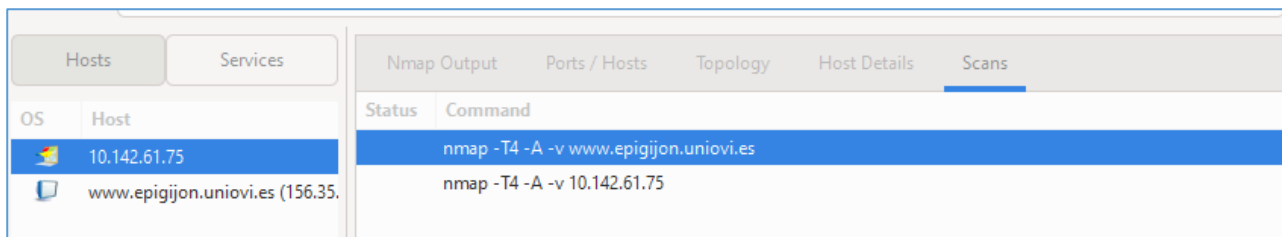
Se recomienda guardarlos dentro del mismo directorio que contiene la configuración de Zenmap. En la ventana siguiente pulsa el botón "Create Folder" para crear el directorio Escaneos.



Finalmente tenemos los dos escaneos en formato XML almacenados en el directorio seleccionado:



Observa la nomenclatura de los ficheros de escaneo: AñoMesDiaHoraMinuto Perfil Objetivo. Comprueba que después de guardar en disco el inventario, el estado de los escaneos ya no es "Sin guardar" (Unsaved) sino que está vacío:



Zenmap usa la convención de que una ventana representa un inventario de red. Si se desea abrir un nuevo inventario sin cerrar el actual, seleccionar el menú "Escaneo" (Scan) de la barra de menús de Zenmap, y seleccionar la opción "Nueva ventana" (New Window).

Para **cargar un inventario almacenado en disco** hay dos posibilidades. Seleccionar el menú "Escaneo" (Scan) de la barra de menús de Zenmap, y seleccionar la opción "Abrir escaneo" (Open Scan). Se crea una nueva ventana y por tanto un nuevo inventario a partir del contenido del directorio seleccionado. Para usar la otra posibilidad selecciona la opción "Abrir Escaneo en esta ventana" (Open Scan in This Window). En este caso no se crea una nueva ventana, sino que los escaneos del directorio seleccionado se añaden a los de la ventana actual.

El **análisis de los resultados** se puede realizar usando varias fichas.

La ficha "Salida Nmap" (Nmap Output) muestra la secuencia de operaciones que realiza Nmap y los resultados que obtiene.

La ficha "Puertos / Servidores" (Ports / Hosts) muestra los puertos de interés del host que está seleccionado en el panel izquierdo. Cuando el puerto está abierto, se muestra un punto (semáforo) verde a su izquierda y cuando está cerrado se muestra un punto (semáforo) rojo.

Cierra Zenmap y ábrelo haciendo uso del escaneo a www.epigijon.uniovi.es que hemos realizado anteriormente. Una vez que lo tengas abierto, pincha en la pestaña "Ports/Hosts" para ver el estado de los puertos que utiliza dicha máquina.

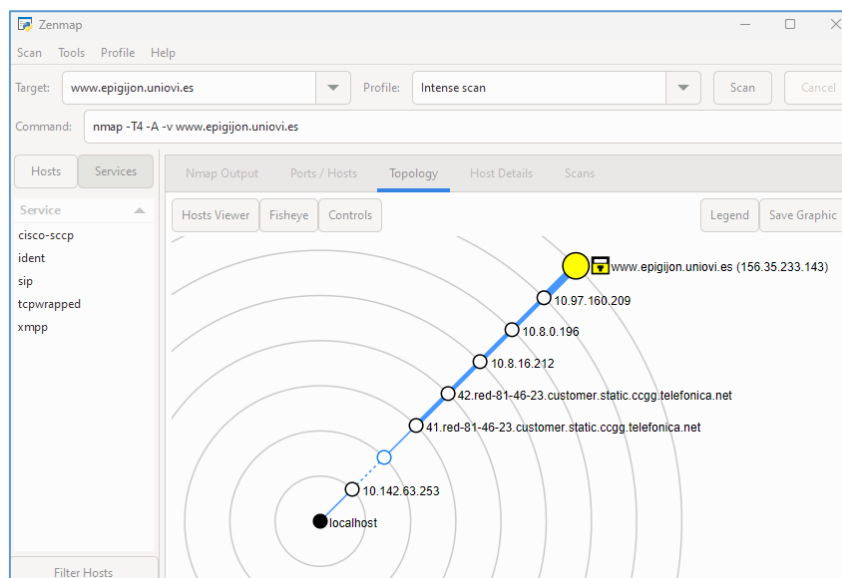
		Nmap Output				Ports / Hosts	Topology	Host Details	Scans
OS	Host	Port	Protocol	State	Service	Version			
	www.epigijon.uniovi.es	113	tcp	closed	ident				
		443	tcp	open	tcpwrapped				
		2000	tcp	open	cisco-sccp				
		5060	tcp	open	sip				
		8010	tcp	open	xmpp				

Selecciona "Servicios" (Services) en el panel izquierdo en vez de "Servidores" (Hosts). Selecciona progresivamente un servicio tras otro en el panel izquierdo y comprueba que en la ficha "Puertos / Servidores" (Ports / Hosts) se muestran todos los servidores (hosts) de nuestro inventario de red que proporcionan el servicio seleccionado.

		Nmap Output				Ports / Hosts	Topology	Host Details	Scans
Service		Port	Protocol	State	Service	Version			
cisco-sccp		113	tcp	closed	ident				
ident		443	tcp	open	tcpwrapped				
sip		2000	tcp	open	cisco-sccp				
tcpwrapped		5060	tcp	open	sip				
xmpp		8010	tcp	open	xmpp				

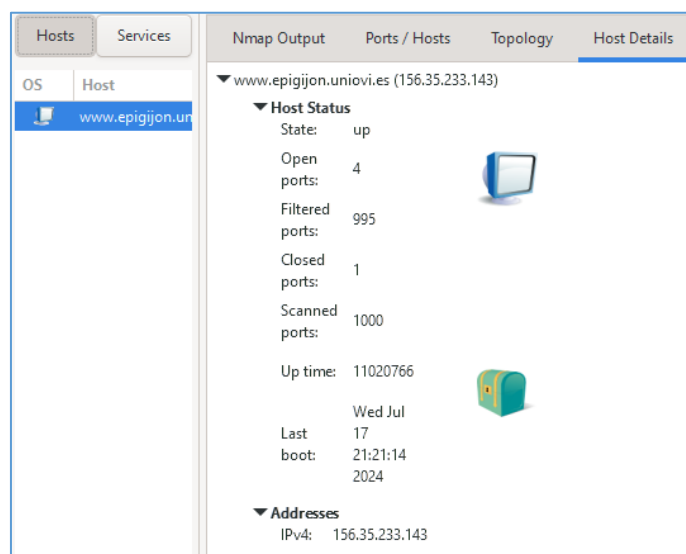
Este puede ser un buen método para responder a una pregunta cómo ¿qué puertos, protocolos y servicios está usando el equipo escaneado y cuáles están abiertos?

La ficha "Topología" (Topology) muestra la topología de la red en un formato determinado. Los servidores (hosts) se ubican en anillos concéntricos. Cada anillo representa un salto de red adicional desde el nodo central (localhost). El gráfico es interactivo. Selecciona un host y comprueba que pasa a ser el centro de la red. Si pinchas en el botón "Leyenda" (Legend), te ofrecerá la leyenda para comprender de forma exacta lo que se está viendo en la figura (conexiones, seguridad de equipos en función de los puertos abiertos, etc.)



Comprueba la funcionalidad que proporcionan los botones "Visualizador de servidores" (Hosts Viewer), "El efecto ojo de pez" (Fisheye) y "Controles" (Controls).

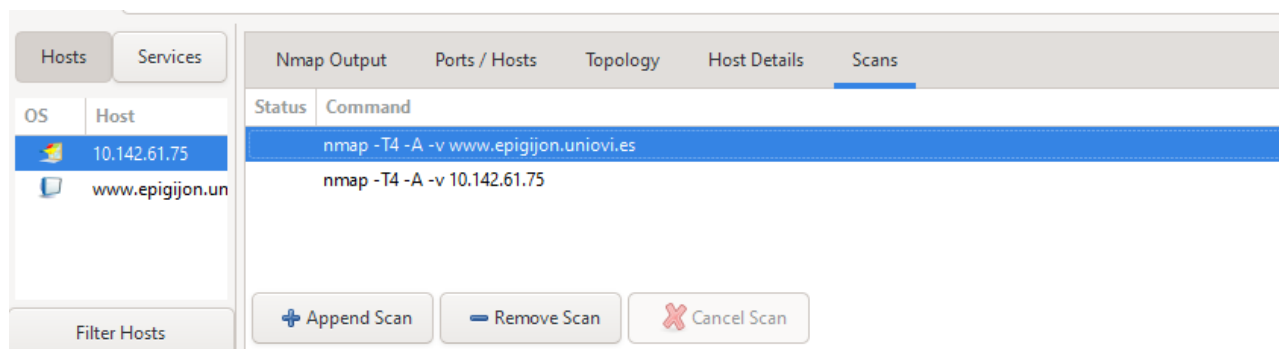
La ficha "Detalles del servidor" (Host Details) muestra la información del host seleccionado en el panel izquierdo. Revisa la información que devuelve esta pantalla y lo que podemos localizar a partir de ella.



Si te fijas, Zenmap asocia un icono a cada host que indica de forma gráfica su vulnerabilidad en función del número de puertos abiertos del modo siguiente:

Puertos abiertos	0-2	3-4	5-6	7-8	9 o más
Icono					

La ficha "Escaneos" (Scans) muestra los escaneos realizados que constituyen el inventario de red actual.



Comprobar la funcionalidad de los botones "Adjuntar escaneo" (Append Scan) y "Quitar escaneo" (Remove Scan) para ver cómo podemos añadir o eliminar escaneos en esta ventana.

4. Escaneo de una red con Nmap (descubrimiento de hosts)

Aunque Zenmap construye de modo automático el comando a ejecutar con Nmap, es necesario conocer cómo se construyen los comandos para particularizar las búsquedas y los escaneos.

El comando inicial, `nmap -T4 -A -v www.epigijon.uniovi.es` se interpreta del modo siguiente:

-T4 indica que se utilice el "Timing Template 4". Un Timing Template es una preselección de varias opciones de temporización. Hay seis plantillas de temporización, T0 a T5, que se pueden usar para acelerar el escaneo (para obtener resultados rápido) o para ralentizar el escaneo (evadir los cortafuegos). Las plantillas disponibles y su comportamiento se resumen en la tabla siguiente:

Plantilla	Nombre	Comportamiento
-T0	Paranoid	Extremadamente lenta
-T1	Sneaky	Útil para evitar a los sistemas de detección de intrusiones
-T2	Polite	Es improbable que interfiera con el sistema objetivo
-T3	Normal	Esta es la plantilla de temporización por defecto
-T4	Aggressive	Produce resultados más rápidamente en redes locales
-T5	Insane	Escaneo muy rápido y agresivo

-A indica que se realice un "Aggressive scan" y es una preselección de varias opciones avanzadas, como `-o -sV -sC --traceroute`, para evitar el teclear una larga línea de comandos.

-v indica que se realice una salida detallada "Verbose output" para que Nmap muestre todos los detalles de las operaciones que va realizando.

La **exploración de una red** con Nmap suele organizarse en **dos fases**: 1ª) Descubrimiento de los hosts de la red realizando escaneos denominados generalmente "Ping scans" y 2ª) Análisis de cada uno de los host realizando escaneos denominados generalmente "Port scans".

Para la **fase de descubrimiento** de los hosts de una red se puede utilizar el perfil de Zenmap denominado "Ping scan", que simplemente utiliza la opción `-sn` de Nmap. Prueba el comando siguiente, donde IP_Red será la IP de la red en la que te encuentras ubicado:

```
nmap -v -sn IP_Red/24
```

La opción `-sn` (**no port scan**) le indica a Nmap que no escanee los puertos de los hosts descubiertos. Además, para la fase de descubrimiento Nmap envía a cada objetivo seleccionado:

Solicitud de echo ICMP

+Paquete TCP SYN al puerto 443

+Paquete TCP ACK al puerto 80

+Solicitud de tiempo ICMP

Observar que el descubrimiento no consiste solo en enviar un paquete de eco ICMP, el clásico ping, sino que el concepto de ping es genérico y se refiere a toda la fase de descubrimiento.

En versiones previas de Nmap la opción -sn se conocía como -sP.

Esta búsqueda descubre unos cuantos hosts rápidamente (en segundos), pero en la subred puede haber más hosts no descubiertos.

Para descubrir los hosts de una red también es posible prescindir de lo que Nmap denomina la fase de descubrimiento, que aunque parezca un contrasentido, se explica a continuación.

Normalmente, Nmap realiza unas operaciones para descubrir los hosts de una red y luego solo en los hosts descubiertos realiza las operaciones de escaneo de puertos, descubrimiento del sistema operativo, etc.

La opción -Pn (**no ping**) indica a Nmap que prescinda de la fase de descubrimiento. Entonces Nmap aplica todas las operaciones de escaneo especificadas (o las que utiliza por defecto si no se han especificado algunas) sobre cada objetivo indicado. **Prueba el comando siguiente donde IP_Red es la IP de la red en la que te encuentras ubicado:**

```
nmap -v -Pn IP_Red/24
```

Esta opción es útil cuando los hosts a escanear están protegidos por un cortafuegos que bloquea los paquetes enviados para descubrirlos. Con esta opción Nmap puede generar una lista de puertos abiertos en hosts que no responden a los comandos ping.

Esta búsqueda descubre muchos más hosts UP, pero necesita mucho tiempo para escanear todos los posibles objetivos (más de 3 horas). **Cancela este escaneo.**

Para particularizar la fase de descubrimiento se puede utilizar diversas opciones:

- -PE = ICMP Echo Ping. Es la opción por defecto si no se especifican otras. Muchos hosts están configurados para no responder a paquetes ICMP por razones de seguridad.
- -PP = ICMP Timestamp Ping. Es otra opción basada en ICMP para intentar recibir una respuesta que no sea bloqueada por los cortafuegos.
- -PS = TCP SYN Ping. Envía un paquete SYN al objetivo y espera la respuesta. Este método puede ser útil para los sistemas que bloquean los pings estándar ICMP.
- -PA = TCP ACK Ping. Envía un paquete TCP ACK al objetivo, aunque no existe una conexión, y espera algún tipo de respuesta. Este método puede ser útil para los sistemas que bloquean los pings estándar ICMP.

Prueba las cuatro opciones separadamente y luego combínalas entre ellas progresivamente hasta terminar así, donde IP_Red es la IP de la red en la que te encuentras ubicado:

```
nmap -v -PE -PP -PS -PA IP_Red/24
```

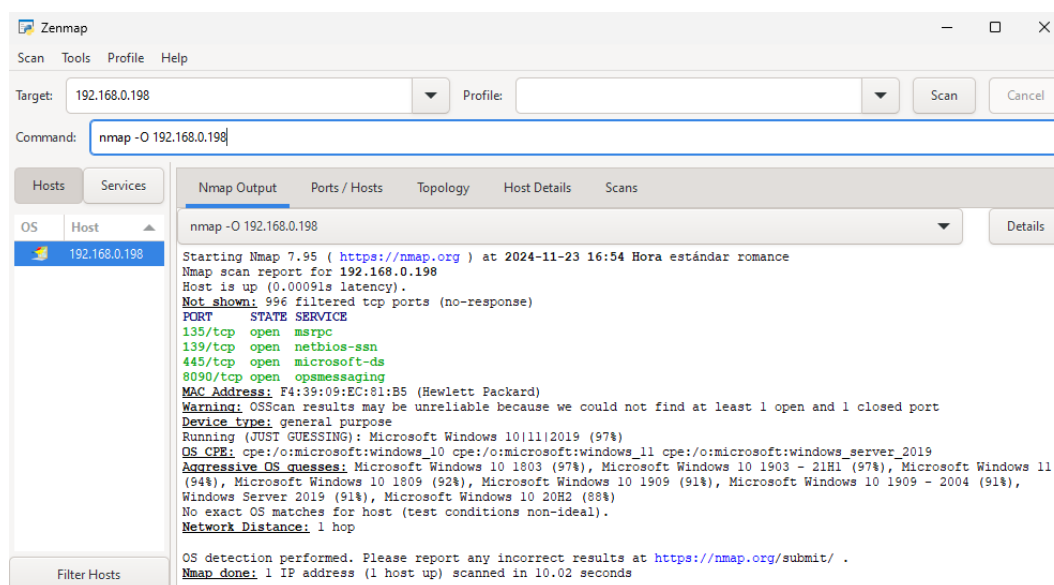
Si no se obtienen buenos resultados se puede emplear la opción -sS (Sondeo TCP SYN). Consulta este concepto de sondeo en la ayuda de Nmap:

<https://nmap.org/man/es/man-port-scanning-techniques.html>

5. Detección del SO y los servicios

El proceso de identificación del SO del objetivo y su versión, se denomina "TCP/IP fingerprinting". El valor de algunos parámetros del protocolo TCP es definido en cada implementación del protocolo, esto es, en cada sistema operativo. Recopilando y almacenando esos valores se puede detectar el sistema operativo que se ejecuta en un host.

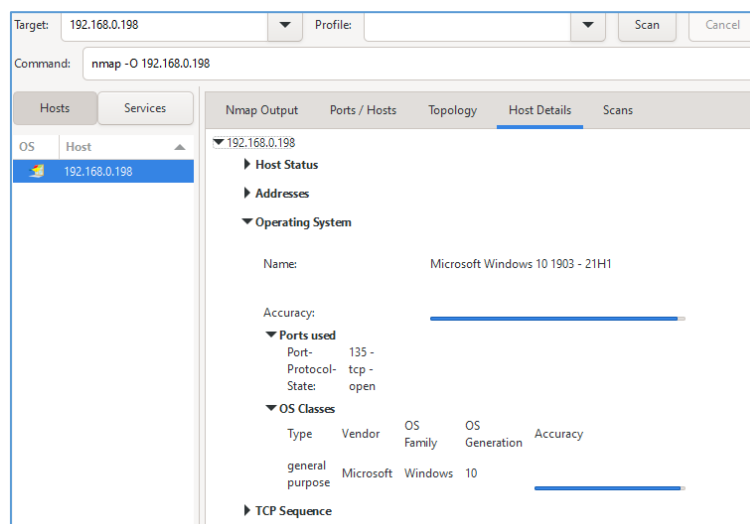
La **opción -O** habilita la detección del SO de los hosts escaneados. En este punto, abre Zenmap y lanza un escaneo al equipo anfitrión. Revisa que las dos máquinas (anfitriona y virtual) estén en la misma red). En el caso de este guión, se usará como máquina anfitriona la IP 192.168.0.198 y como máquina virtual la IP 192.168.0.196. Todos los escaneos se realizan desde la máquina virtual aunque sea a sí misma.



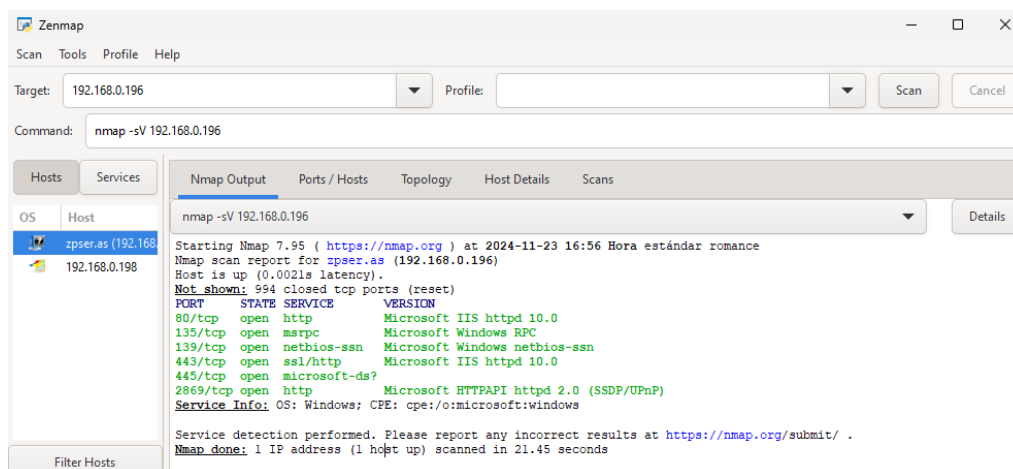
Para que funcione correctamente es necesario que Nmap encuentre al menos un puerto abierto y un puerto cerrado en el host. Si Nmap no es capaz de detectar el SO se puede forzar a Nmap a generar una estimación usando la opción `--osscan-guess`.

También se puede indicar a Nmap que identifique los vendedores y las versiones del software que proporciona el servicio en cada puerto abierto detectado.

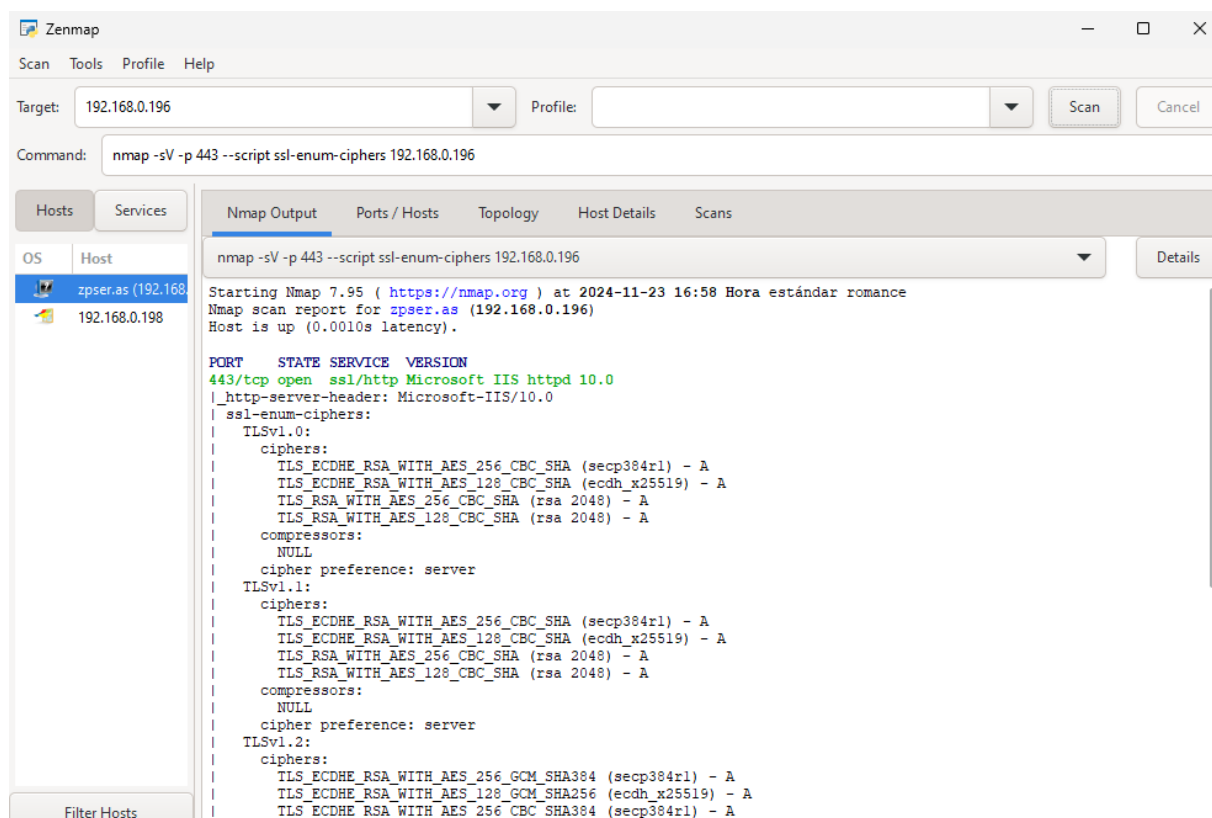
Si accedes a los detalles del host (Host Details) puedes ver el detalle del SO que está utilizando la máquina y la precisión con el que lo detecta.



La **opción -sV** habilita la identificación de los servicios. Lanza un escaneo de este tipo a la IP de la máquina virtual que tendrá más servicios corriendo que la anfitriona y comprueba el resultado. Mira que tiene un IIS en su versión 10, así como los servicios desplegados en cada uno de los puertos que ofrece.



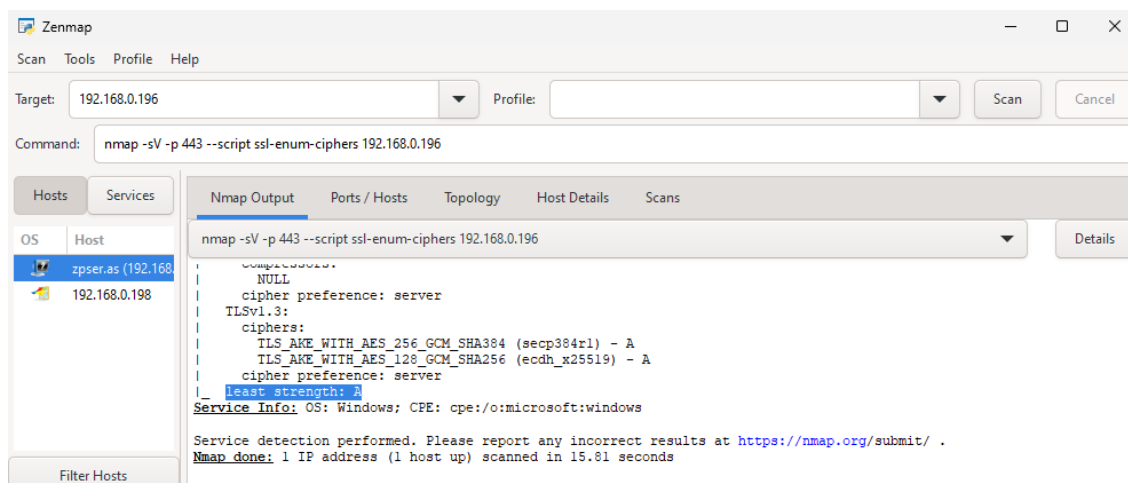
Nmap dispone de scripts específicos para determinar las características de un servicio proporcionado por un host concreto. Por ejemplo para determinar la seguridad de SSL/TLS se puede usar el comando siguiente: `nmap -sV -p 443 --script ssl-enum-ciphers IP_aEscanear` para comprobar la fortaleza de la seguridad. **Realiza un escaneo de este tipo** sobre la máquina virtual para comprobar lo seguro que es el servidor que montamos en prácticas anteriores.



Observa que el comando enumera las versiones de TLS soportadas junto con los conjuntos de cifrado soportados en cada versión. Este comando también se puede usar sin la opción -sV.

Al listar los conjuntos de cifrado soportados por SSL/TLS es interesante comprobar que asigna una letra a cada cifrado. Esa letra da una indicación de la robustez del conjunto.

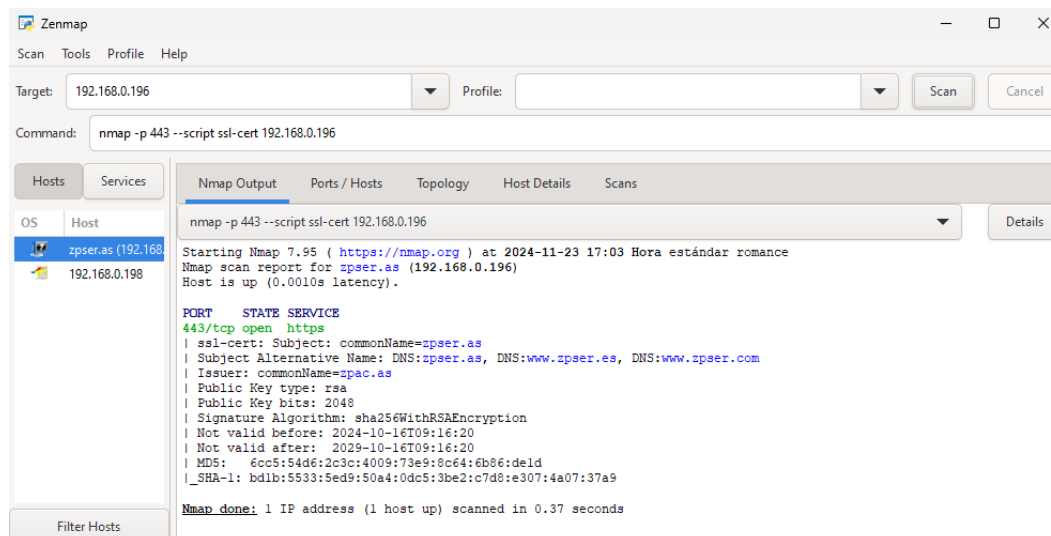
La última línea de la información proporcionada muestra el nivel de robustez del conjunto de cifrado con la menor robustez (least strength). El nivel se indica con una letra: A (mejor) a F (peor).



Para obtener información sobre la calificación de la robustez se puede consultar:

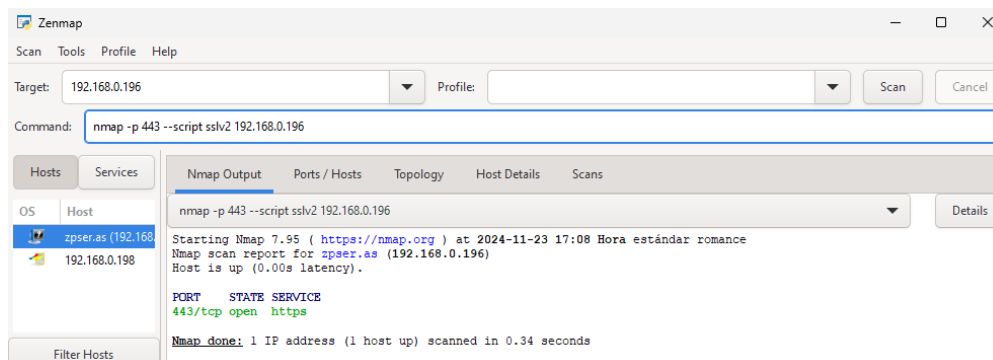
<https://github.com/ssllabs/research/wiki/SSL-Server-Rating-Guide>

También hay un script para obtener información sobre el certificado que utiliza un servidor para trabajar con SSL/TLS: `nmap -p 443 --script ssl-cert IP_aEscanear`. Realiza este comando para obtener información sobre el certificado que utiliza el sitio seguro montado en la máquina virtual.



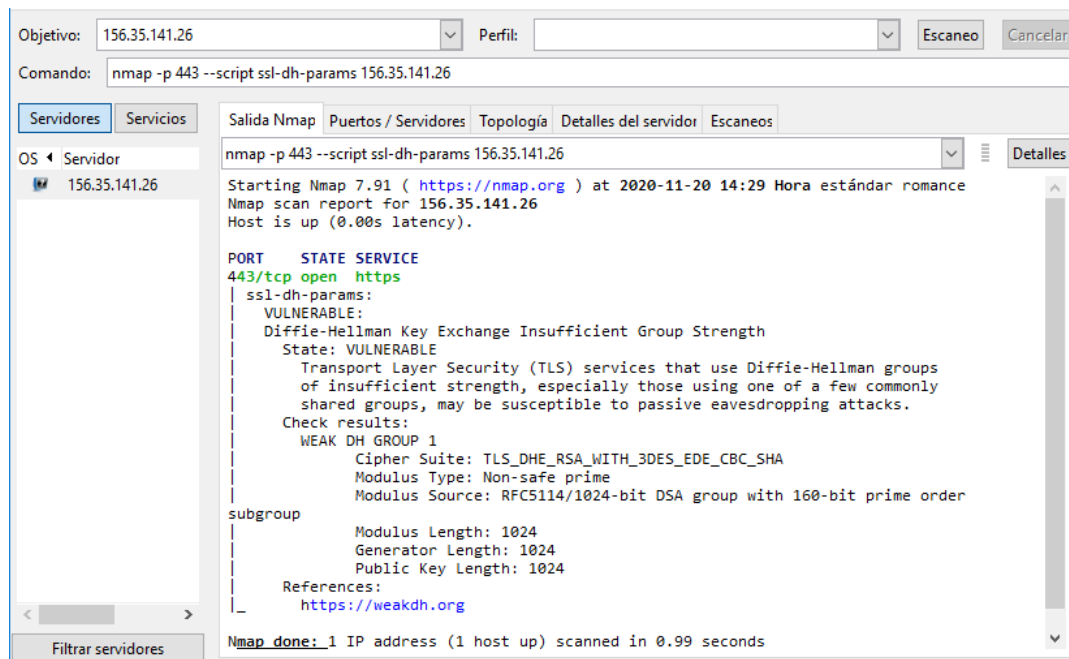
Hay múltiples scripts para comprobar si hay vulnerabilidades específicas.

Para comprobar si el servidor, permite el uso de SSL V2.0 se puede usar: `nmap -p 443 --script sslv2 IP_aEscanear`. Realiza la comprobación.



Como no devuelve nada se interpreta que no existe la vulnerabilidad que representa el uso de SSL en su versión 2.0.

A continuación, y a modo de ejemplo, se muestra un script para comprobar si existe alguna vulnerabilidad en los conjuntos de cifrado que utilizan el algoritmo de Diffie-Hellman para acordar claves sobre un servidor de Uniovi. El comando es: `nmap -p 443 --script ssl-dh-params IP_aEscanear`. Si estás en clase cuando realices esta parte, intenta realizar el comando para ver si devuelve el mismo resultado, en caso de estar en casa, no hace falta que lo realices, ya que no conseguirás conectividad con el servidor.



En este caso, el script de Nmap si informa de la presencia de vulnerabilidades detectadas por el software Zenmap.

6. Evasión de cortafuegos

Nmap incluye algunos mecanismos que pueden ayudar a evadir los cortafuegos y los sistemas de detección de intrusiones.

La **opción -f** indica a Nmap que envíe paquetes de 8 bytes, fragmentando entonces los mensajes de prueba que envía Nmap en muchos paquetes muy pequeños. No obstante, los sistemas de defensa actuales, si están bien configurados, suelen detectar esta situación, y esta opción no sería útil.

La **opción -D** se usa para enmascarar un escaneo utilizando señuelos (*decoys*) del modo siguiente:

```
nmap -sn -D 192.168.0.2,192.168.0.3 192.168.0.0/24
```

Con este comando Nmap utiliza dos direcciones adicionales de origen falsas (acabadas en 2 y 3), además de la suya propia, para enviar paquetes. El objetivo es aparentar que se está realizando un escaneo distribuido desde múltiples máquinas y complicar el rastreo del origen del escaneo.

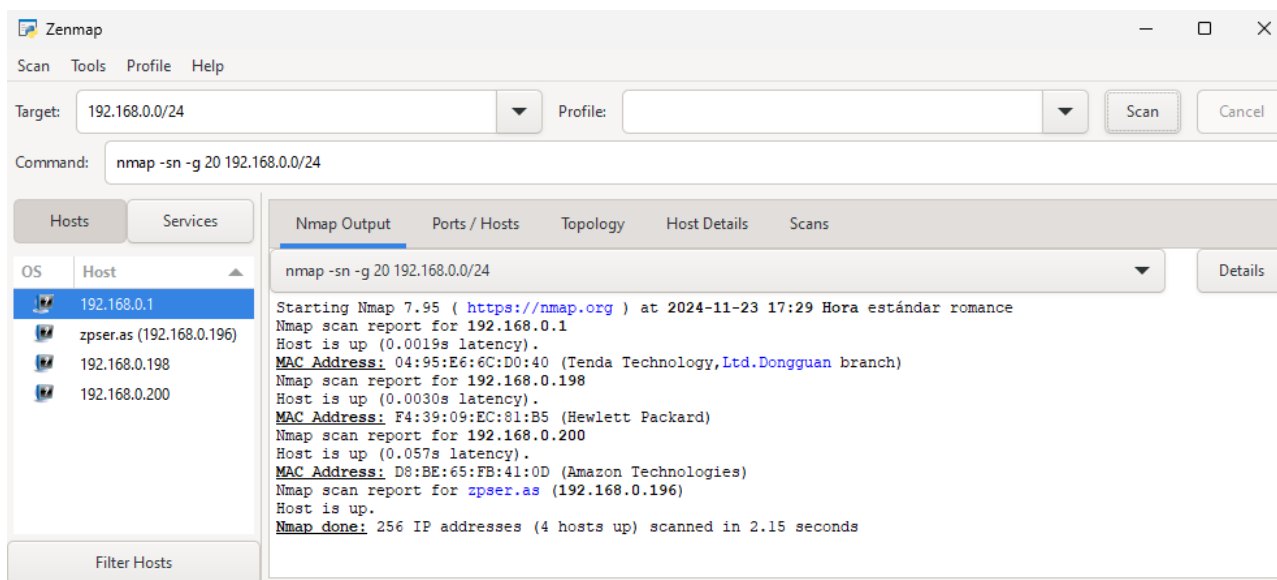
Otra posibilidad es indicar a Nmap que genere aleatoriamente un determinado número de direcciones de origen falsas. Por ejemplo para indicar que utilice 10 señuelos aleatorios:

```
nmap -sn -D RND:10 192.168.0.0/24
```

La **opción --source-port** permite especificar el número de puerto origen en los paquetes enviados por Nmap en cada prueba. Por defecto Nmap utiliza un número de puerto aleatorio para cada prueba. La idea es que hay cortafuegos que aceptan directamente el tráfico que proviene de determinados puertos: 20 (FTP), 53 (DNS), 67 (DHCP). Para indicar esta opción se suele usar la abreviación -g tal como se muestra en el ejemplo siguiente:

```
nmap -sn -g 20 192.168.0.0/24
```

Prueba alguna de estas opciones para llevar a cabo un escaneo. A modo de ejemplo se muestra la siguiente figura en la que se ven los dispositivos que hay en la red, así como su dirección MAC y si está “levantado” (up) o no lo está.



Hay muchas más opciones que se pueden consultar en los libros especializados sobre este tipo de cuestiones.

Monitorización y Auditoría de Seguridad

Práctica 4 - Online

1. Objetivo

El objetivo de esta segunda parte será el de familiarizar al alumnado con el concepto de auditoría de seguridad. En concreto se realizará auditoría de seguridad en Windows atendiendo al visor de eventos que nos ofrece. Se pretende que el alumnado pueda iniciarse en el mundo del análisis forense a bajo nivel, atendiendo a los propios eventos generados por el sistema. El alumnado deberá ser capaz de 3 objetivos fundamentales:

- Activar y configurar los controles de seguridad.
- Activar y configurar la auditoría de seguridad para el control de eventos.
- Analizar los registros de eventos de seguridad para evaluar problemas de seguridad.

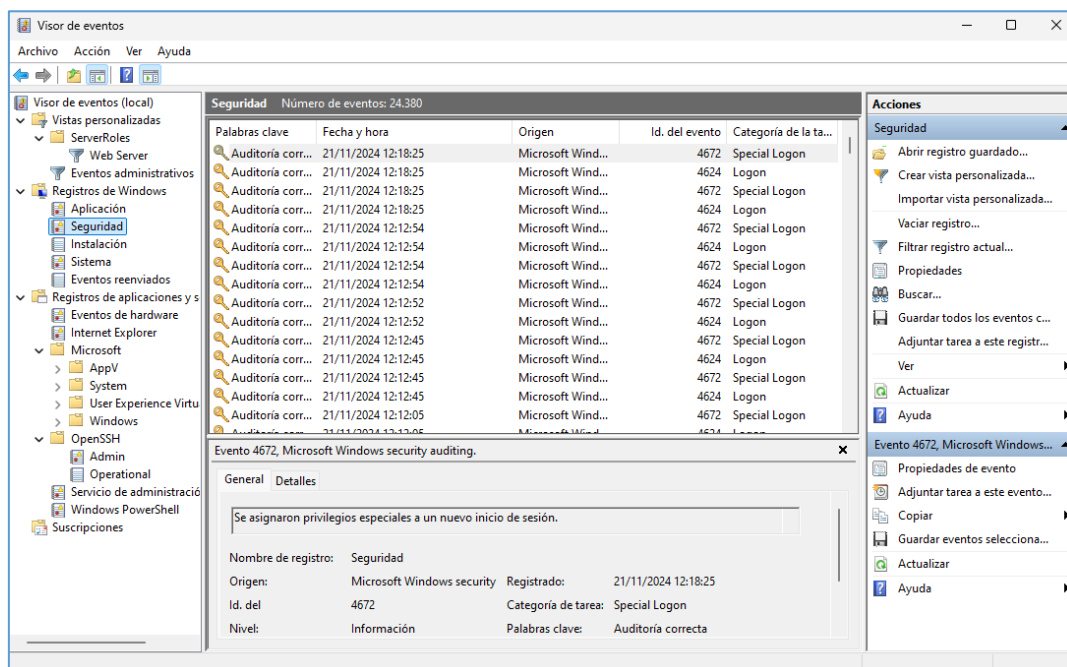
2. El visor de eventos de Windows

Permite analizar registros de eventos. Para arrancar el visor de eventos hacer:

Inicio > Panel de control > Herramientas de Windows > Visor de eventos

O teclear **eventvwr** (*event viewer*) en la consola.

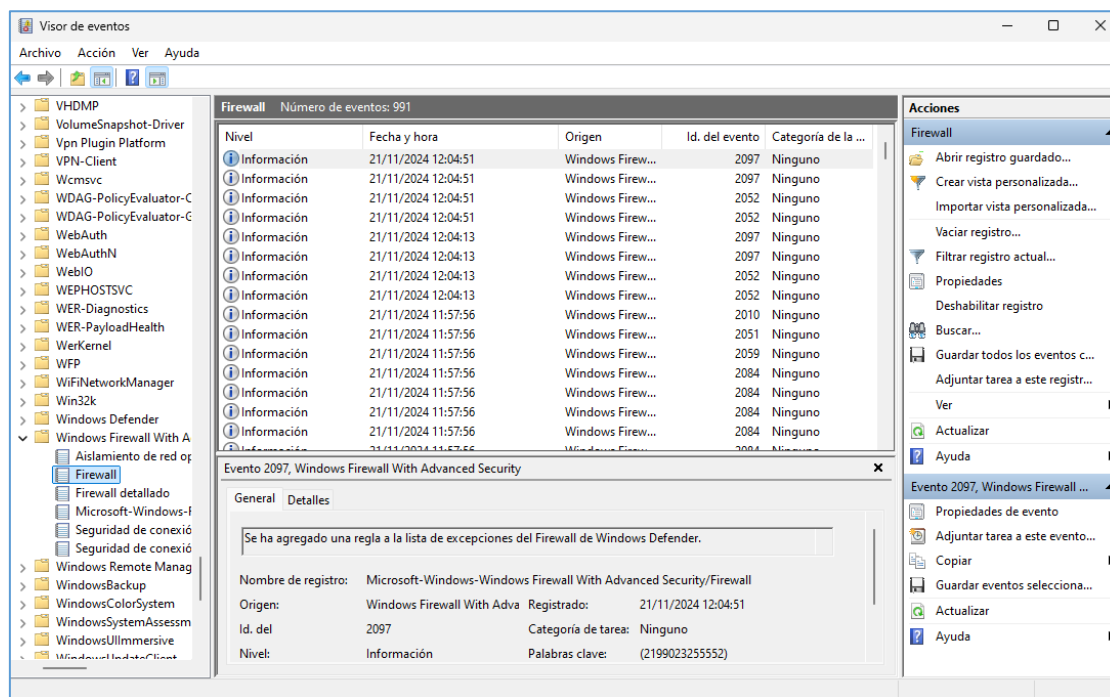
Desplegar el árbol del visor en el panel izquierdo y al seleccionar "Seguridad" aparece:



El uso del visor es totalmente intuitivo. La parte interesante para la asignatura se centra en los Registros de Windows, y en particular en el Registro de Seguridad de Windows.

También pueden ser de interés algunos "Registros de aplicaciones y servicios". Por ejemplo en:

Reg app y serv > Microsoft > Windows > Windows Firewall With Advanced Security > Firewall



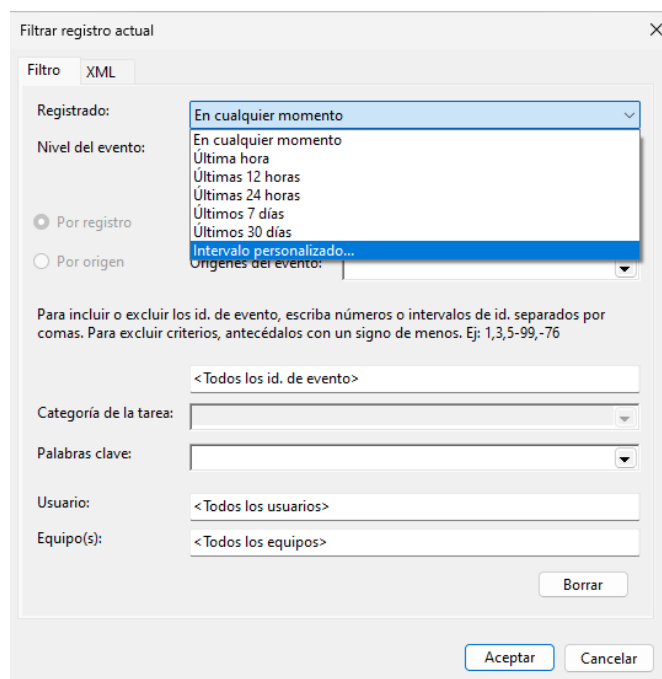
Observar los eventos que hay en el registro con las directivas de auditoría que tiene activadas el sistema por defecto. Buscar información en Internet sobre los códigos numéricos que aparecen.

Luego, realizar tareas como Buscar, Filtrar, Guardar, etc.

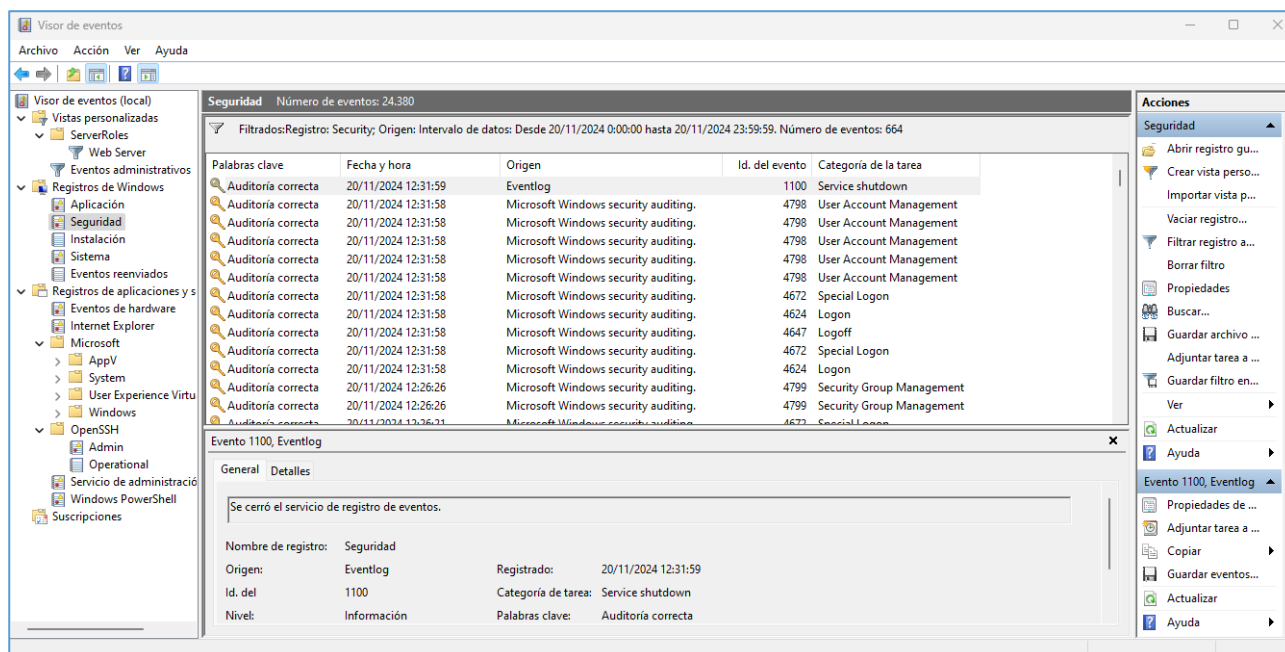
Ejemplo: guardar todos los eventos de seguridad de todo un día, por ejemplo de antes de ayer.

En el panel izquierdo, vuelve a seleccionar el Registro de Windows “Seguridad”. En el panel derecho de Acciones selecciona “Filtrar registro actual...”.

En la ventana emergente “Filtrar registro actual” usa el campo Registrado y cambia la opción “En cualquier momento” por la opción “Intervalo personalizado...” y propón que revise un día concreto (por ejemplo, ayer) desde las 00:00:00 a las 23:59:00.



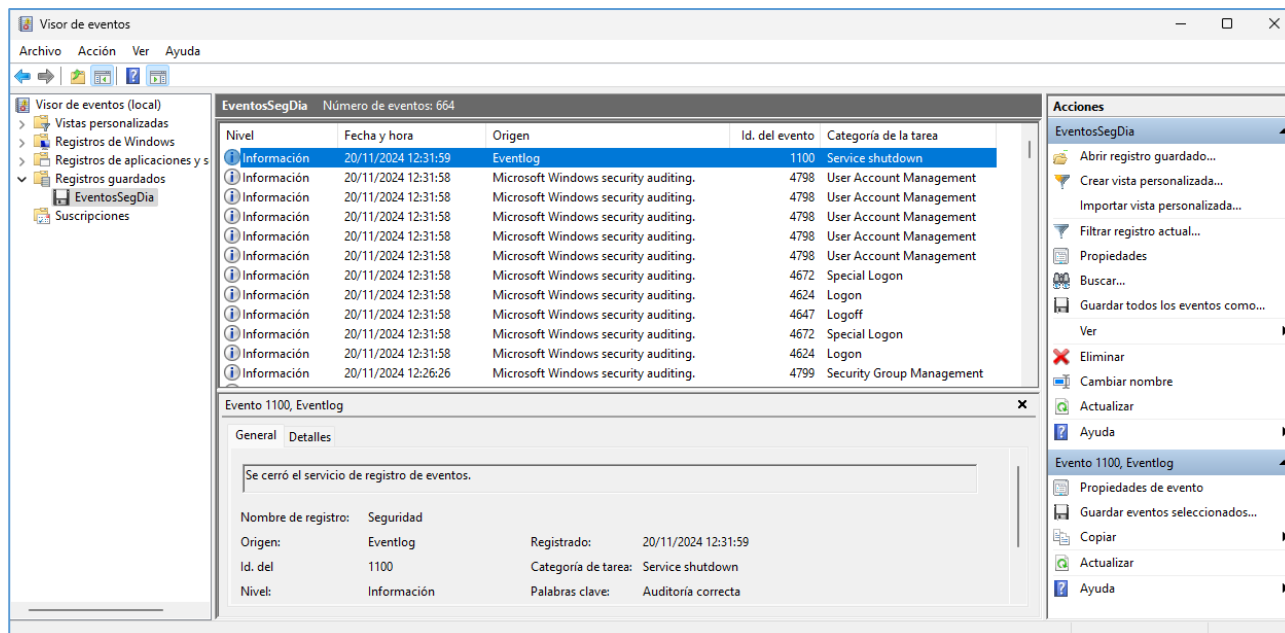
Tras el filtrado, el visor muestra una ventana como la siguiente. Debes ensanchar el panel central para poder ver el número de eventos en la esquina superior derecha del panel.



Como puedes ver se pueden ver unos 25.000 eventos relativos a la seguridad que fueron auditados por el sistema pero no todos corresponden al fichero que debemos obtener, para poder verlos, selecciona la Acción “Guardar archivo de registro filtrado como...” visible en el lado derecho del visor de eventos y guarda los eventos en un fichero llamado *EventosSegDia*.

Ahora debes cerrar el Visor de eventos.

Vete al directorio donde esté el fichero con los eventos guardados (.evtx) y haz doble clic sobre él. Se abre el Visor de eventos mostrando en el panel izquierdo un nuevo elemento: Registros guardados, que contiene el fichero seleccionado. Además, los eventos del fichero se muestran en el panel central tal como se muestra en la figura siguiente:



Borra “EventosSegDia” en el panel izquierdo del Visor de eventos. Comprueba que el Visor ya no dispone de los eventos, pero que el fichero continua en el directorio en el que estaba almacenado.

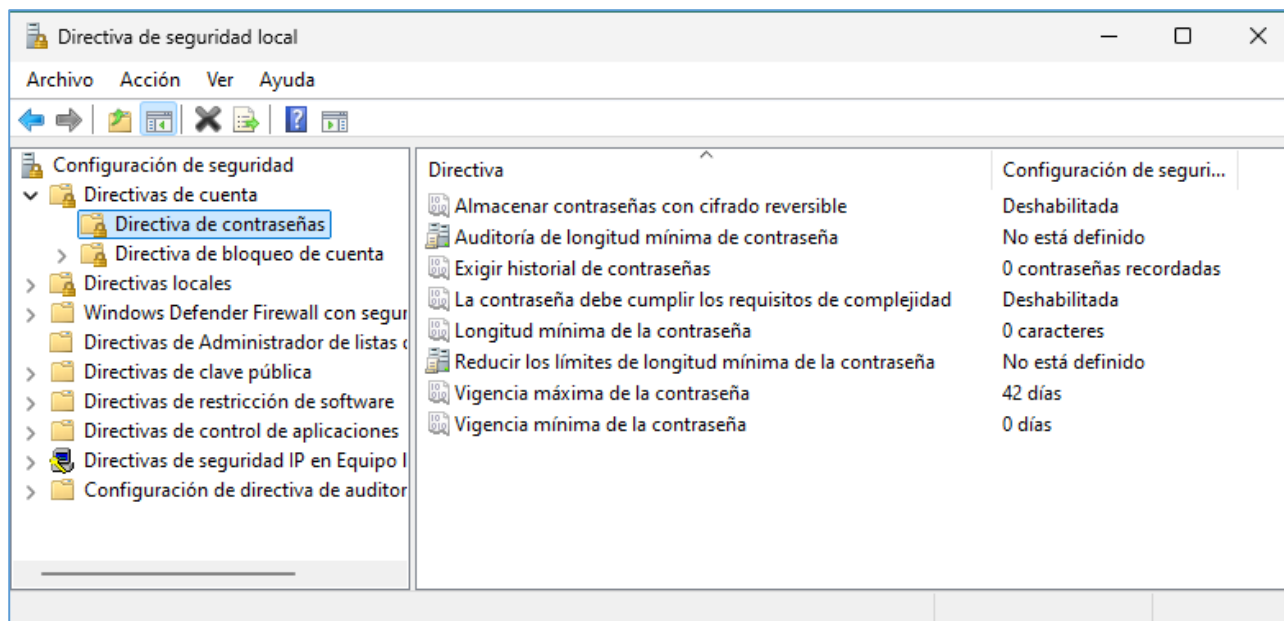
El elemento Registros guardados del Visor de eventos funciona como una tabla de acceso rápido a los ficheros con los que ha trabajado el Visor pero no representa el fichero en sí, por lo que el fichero seguirá almacenado en su lugar original.

3. El visor de eventos de Windows

En un sistema operativo, como Windows, hay muchos controles de seguridad que se pueden activar/desactivar y configurar. Una de las herramientas que permite configurar varios controles de seguridad es la “Directiva de seguridad local” (secpol). Para usar esta herramienta hacer:

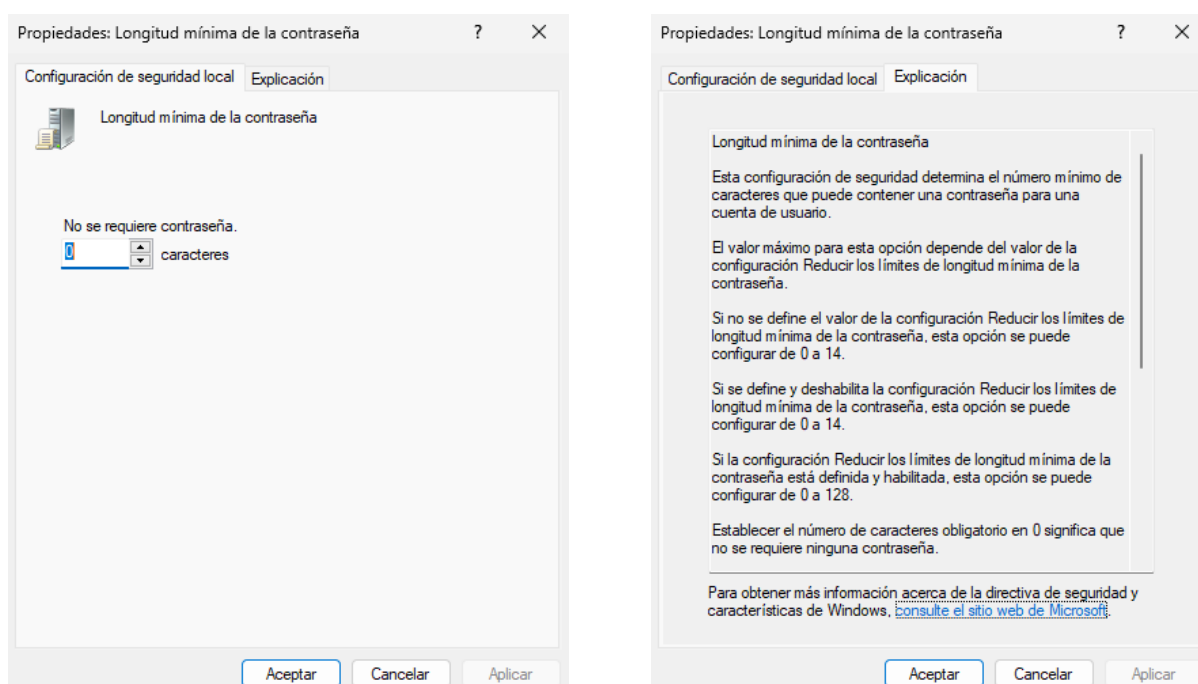
Herramientas de Windows > Directiva de seguridad local

O teclear **secpol** (*security policy*) en la consola. Se despliega la siguiente ventana:

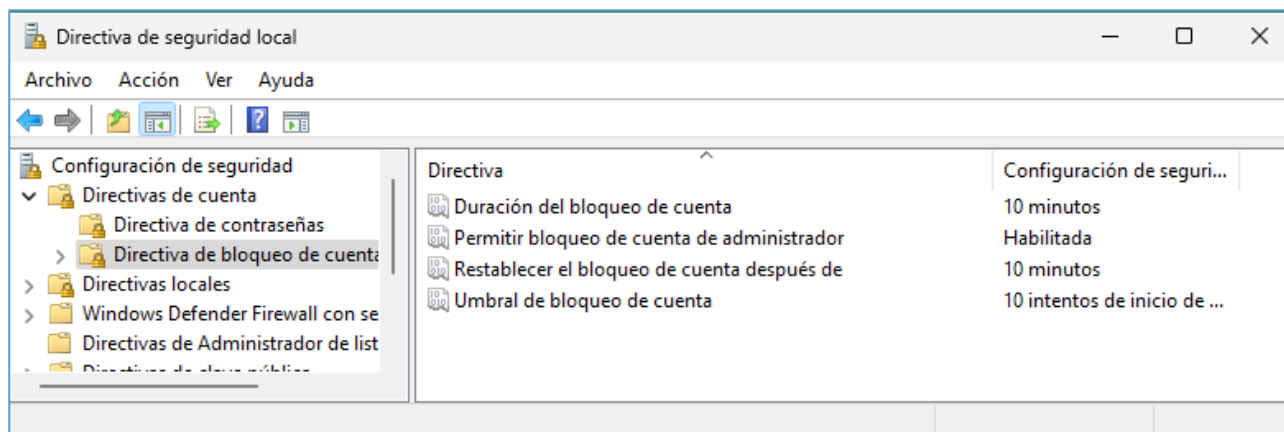


El panel de la izquierda contiene múltiples opciones de "Configuración de seguridad". En la ventana anterior se ha seleccionado la opción “Directivas de cuenta > Directiva de contraseñas”. En el panel derecho se puede observar las directivas y su configuración.

Por ejemplo la directiva “Longitud mínima de la contraseña” está configurada a 0 caracteres. Haz doble clic en la directiva para cambiar su configuración. Aparecen estas ventanas:



Observar la “Directiva de bloqueo de cuenta”:



Observar las opciones que ofrece y aprender a configurar el bloqueo. **Comprueba lo que hacen estas directivas de seguridad.**

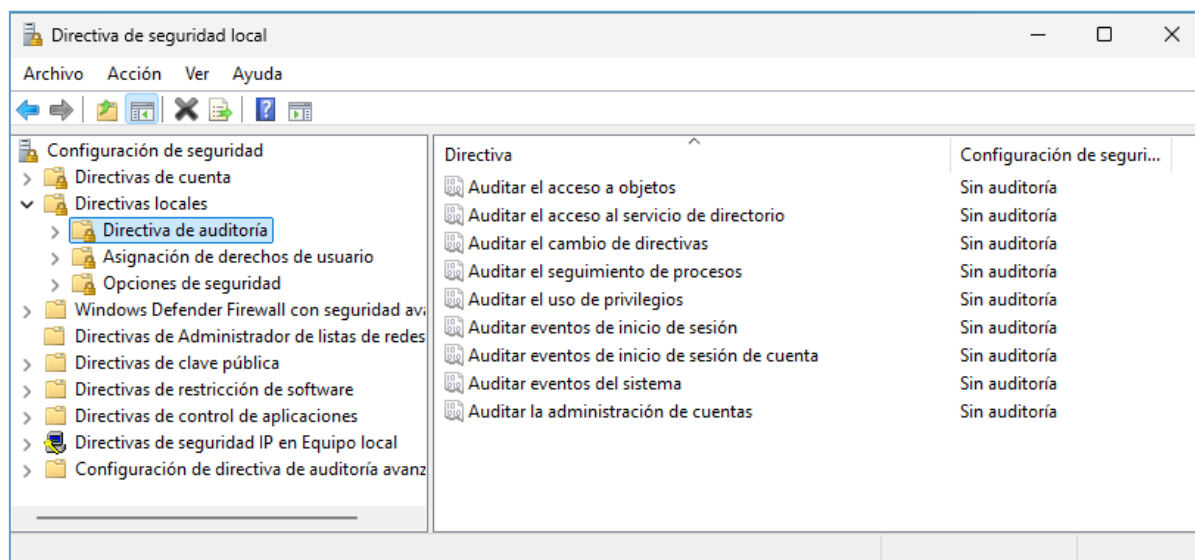
En la opción del panel izquierdo “Directivas locales” observar las directivas que se pueden configurar en “Asignación de derechos de usuario” y en “Opciones de seguridad”.

Comprueba que en la opción “Windows Defender Firewall con seguridad avanzada” da acceso a la configuración de Firewall de Windows, pero la configuración se puede hacer en el propio Firewall, ya que aquí no se muestran inicialmente reglas (a no ser que las creamos). No crees de momento ninguna más.

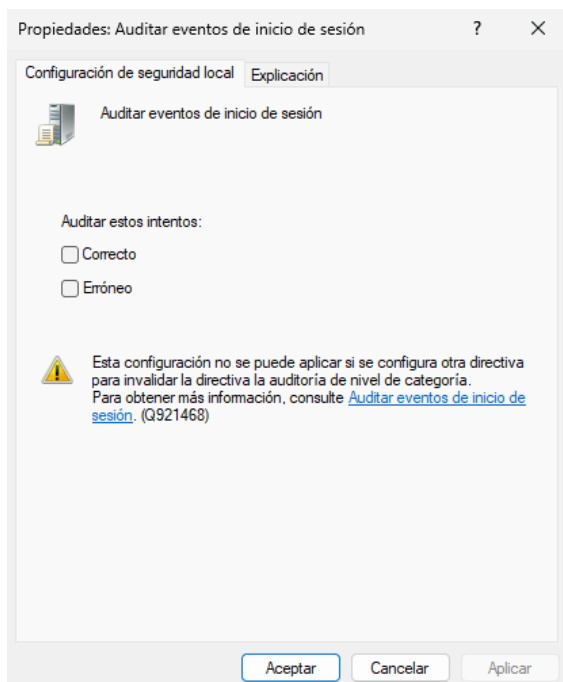
Observa el resto de tipos de Directivas que permite configurar la herramienta, para tener una idea de lo que permite configurar la herramienta *secpol*. Para usarlas correctamente, primero hay que conocer la tecnología con la que trabajan.

4. Configurar los eventos de auditoría que se deben registrar

Una forma de establecer los eventos de auditoría a registrar es mediante la herramienta *secpol*. Para la auditoría es interesante, dentro de **Directivas locales**, la opción “**Directiva de auditoría**”. También es interesante el último grupo “**Configuración de directiva de auditoría avanzada**”.



Observar en la figura anterior que la "Directiva de auditoría" permite auditar las categorías que se muestran en el panel derecho. Si se selecciona una directiva cualquiera del panel derecho aparece una ventana como la siguiente:



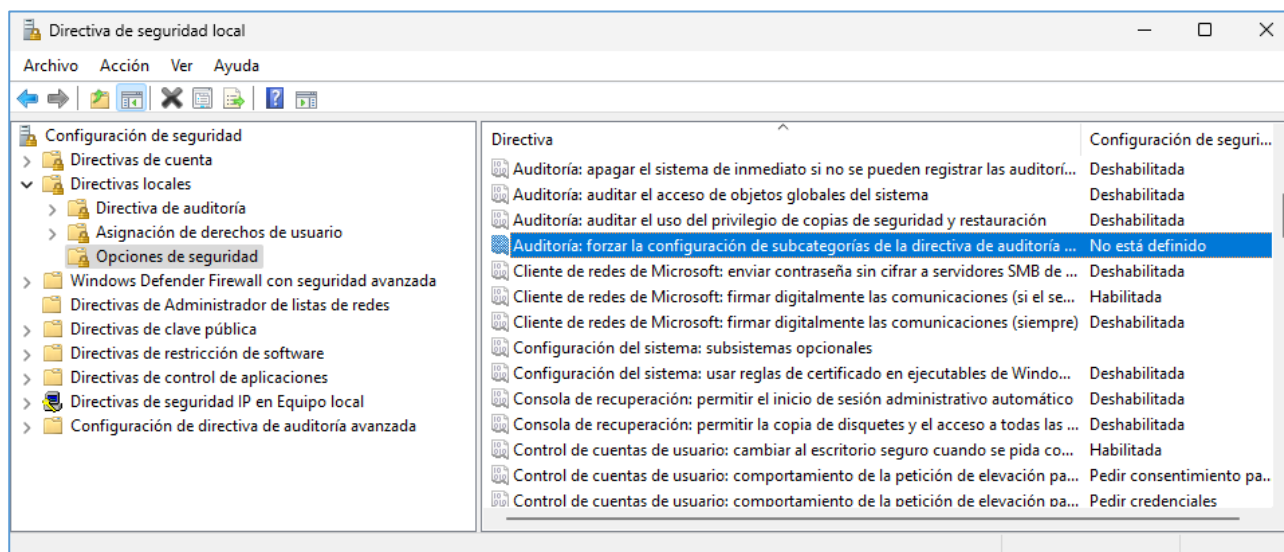
Observa que podríamos tener hasta 4 opciones:

- 1) No auditar los inicios de sesión, dejando sin seleccionar ambas casillas.
- 2) Auditar solo los inicios de sesión correctos, seleccionando solo la casilla "Correcto".
- 3) Auditar solo los inicios de sesión erróneos, seleccionando solo la casilla "Erróneo".
- 4) Auditar los inicios de sesión correctos y los erróneos, seleccionando ambas casillas.

Para las nueve directivas de auditoría se puede seleccionar las cuatro opciones anteriores. Para disponer de mayor detalle en la selección de los eventos a auditar es necesario utilizar la "Configuración de directiva de auditoría avanzada".

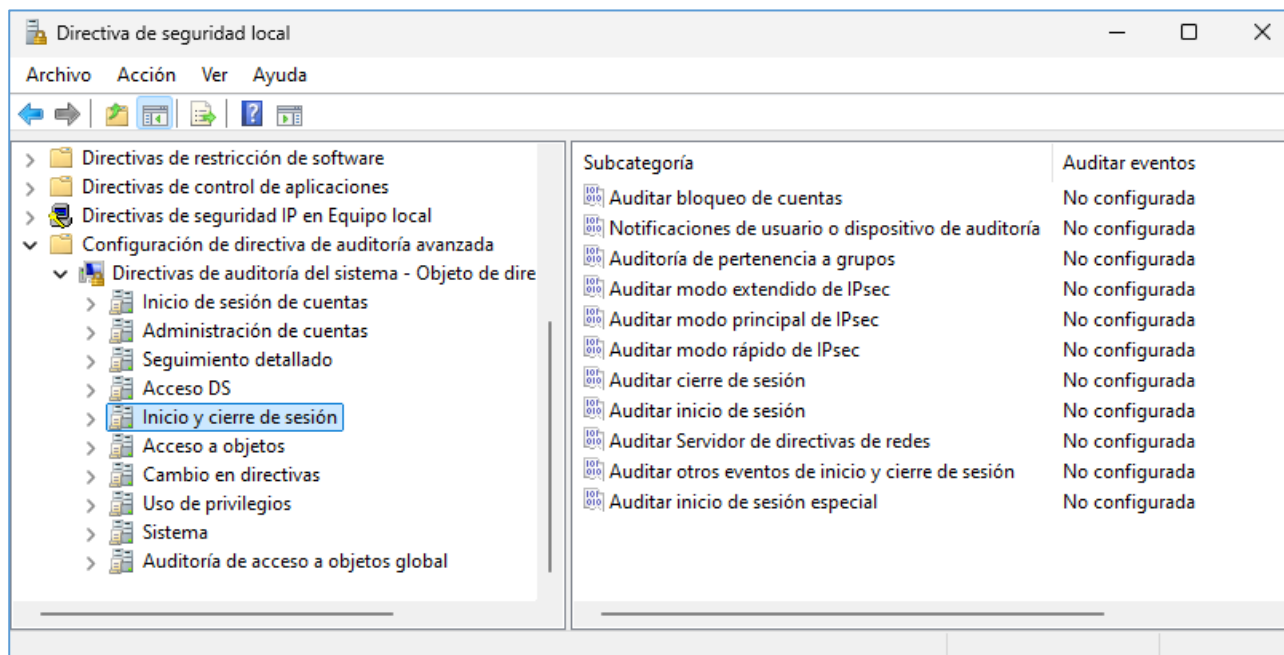
En las prácticas de la asignatura de SLGD se debe usar la Auditoría Avanzada.

Para activarla hay que ir primero a "Opciones de seguridad" en el panel izquierdo y luego en el panel derecho seleccionar la directiva "Auditoría: forzar la configuración de subcategorías ..." como muestra la figura siguiente:

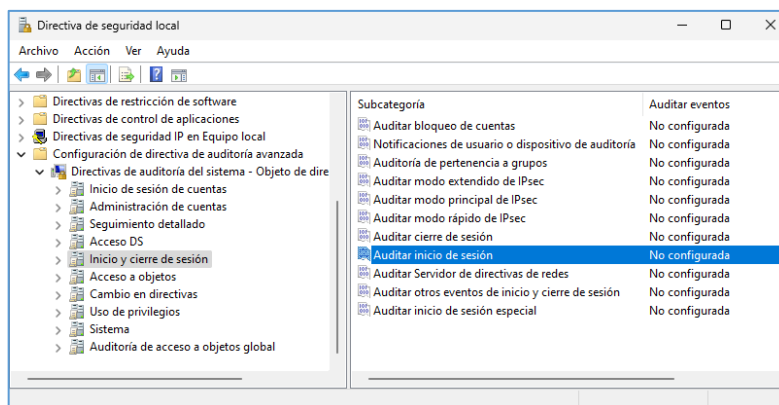
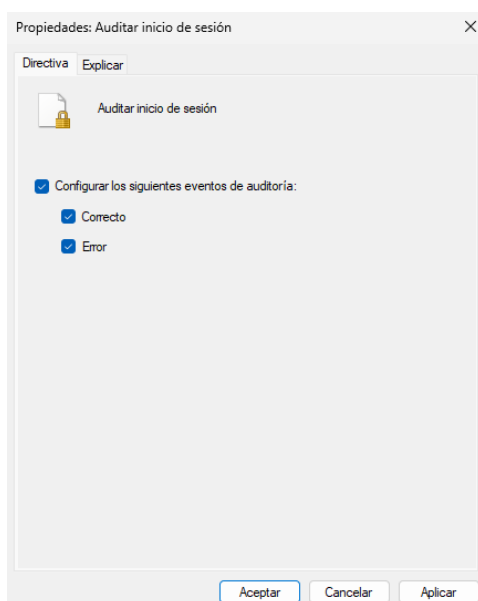


Hacer doble clic sobre la directiva y en la ventana que se muestra, pulsa "Habilitada" para que se habilite y sea de aplicación, ya que como veíamos previamente la configuración de seguridad no estaba definida.

Después desplegamos la última opción del panel izquierdo. Observar que en el panel izquierdo tenemos las mismas directivas (o categorías) de auditoría que aparecían antes en el panel derecho. Pero ahora al seleccionar una en el panel izquierdo aparecen en el panel derecho sus subcategorías.

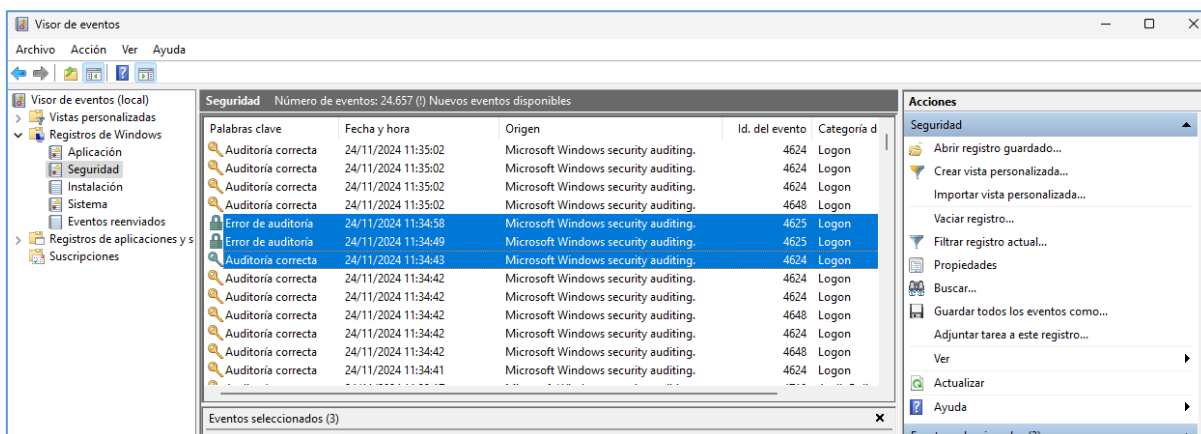


Ahora, el Inicio y cierre de sesión permite auditar nueve eventos independientes. Por ejemplo, seleccionar en el panel derecho "Auditar inicio de sesión" y auditar tanto los inicios correctos como los intentos de inicio que generan un error.



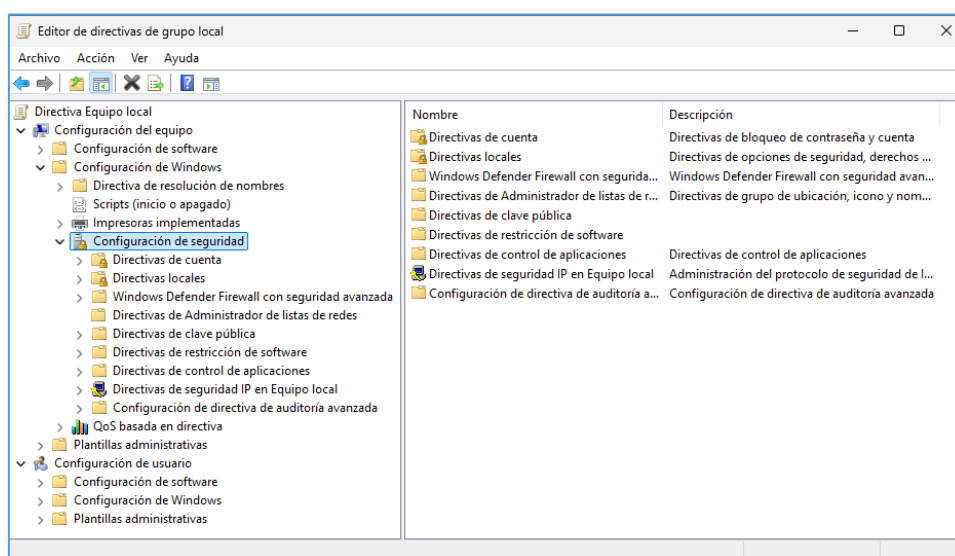
Vamos a comprobar que el SO está realizando la captura de eventos de auditoría del inicio de sesión de forma adecuada. Para ello, cierra la sesión en Windows y haz dos intentos de logon con contraseña incorrecta. Al tercer intento usar la contraseña correcta para acceder nuevamente al sistema.

Si todo ha salido bien, una vez que vuelvas a ver el Visor de Eventos y accedas a este tipo de eventos dentro de los registros de Windows (Seguridad), podrás ver cómo se han registrado dichos eventos y observarás algo parecido a esto:



Otra forma de acceder a esta funcionalidad es usando el Editor de directivas de grupo local.

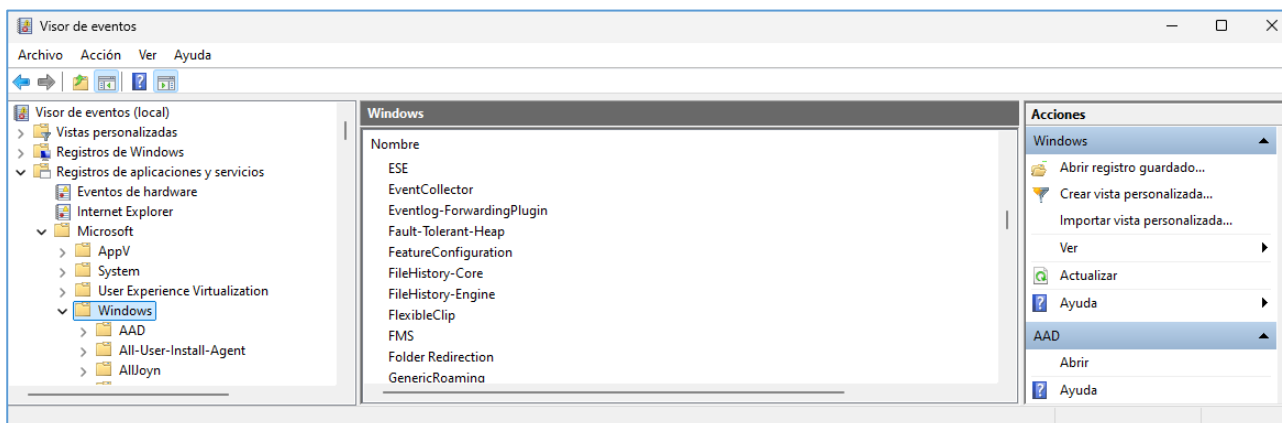
Ejecutar **gpedit.msc** en una consola y aparece la ventana siguiente:



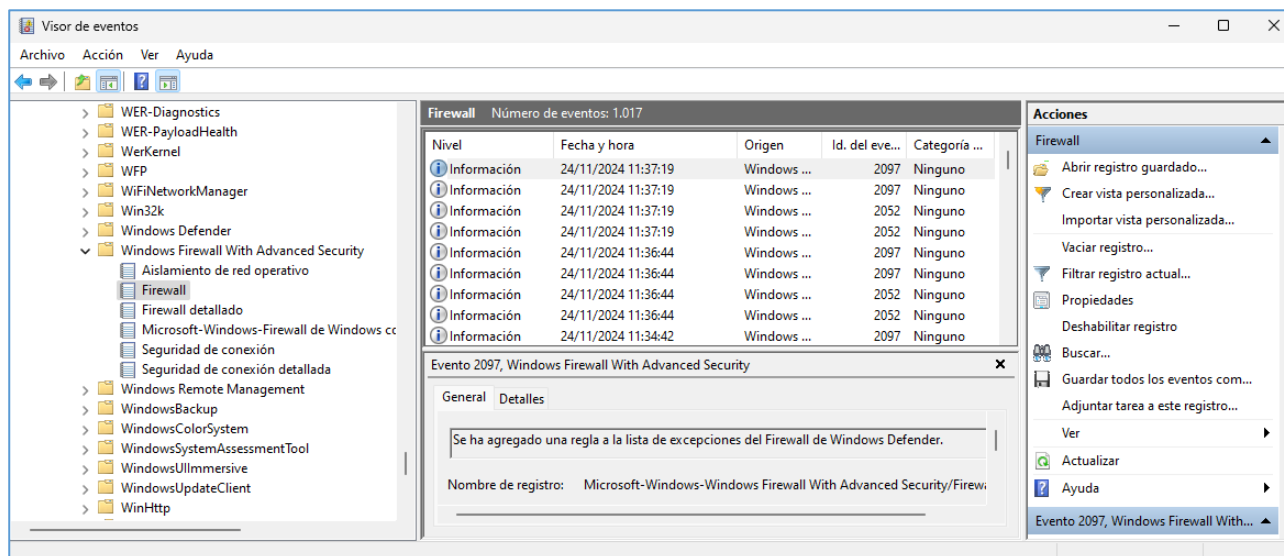
Como se puede comprobar dentro de toda la "Configuración del equipo" tenemos una sección dedicada a la "Configuración de seguridad" en la que podemos configurar directivas.

5. Auditar el cortafuegos

Para ver los eventos que genera el Firewall en el Visor de Eventos hay que navegar en el panel izquierdo del visor: Registros de aplicaciones y servicios > Microsoft > Windows >



Y seguimos ... > Windows Firewall With Advanced Security

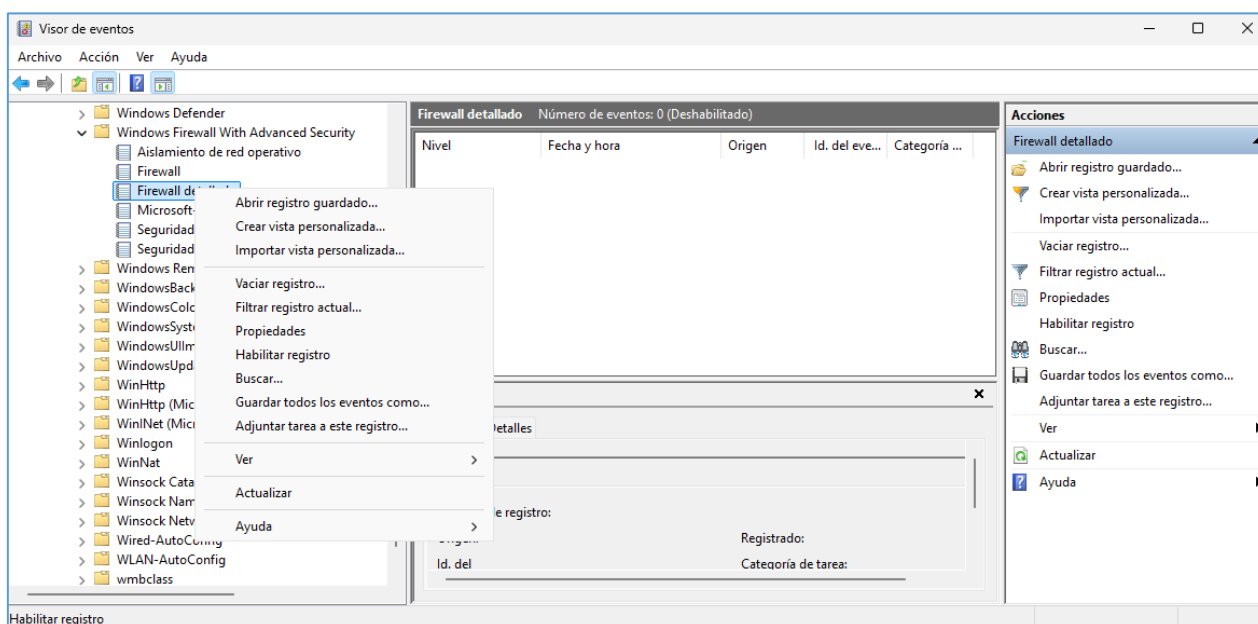


Se puede ver que hay varios registros de eventos disponibles.

El registro "**Firewall**" contiene los eventos relacionados con la configuración del Firewall. Se añade un evento cada vez que se añade, quita o modifica una regla, o cuando se cambia el perfil de una interfaz de red. Compruébalo analizando unos cuantos eventos que aparecen en el panel central del visor de eventos.

El registro "**Firewall detallado**" contiene los eventos relacionados con el estado operativo del Firewall. Por defecto este registro está deshabilitado. Para activarlo hacer clic en el botón derecho del ratón y seleccionar "Habilitar registro" en el menú contextual que aparece. También se puede habilitar en el panel derecho de acciones. Observar que el menú contextual que aparece contiene exactamente las mismas opciones que el panel derecho de acciones.

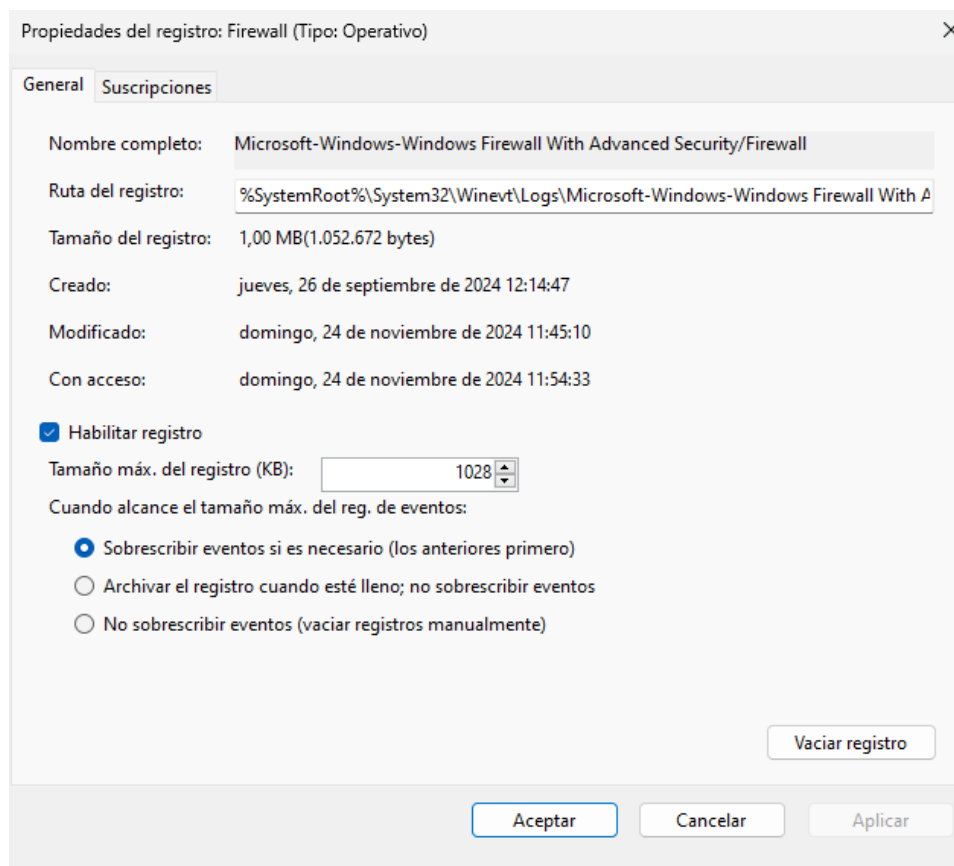
Parece que este registro no es muy útil, pues casi todos los cambios relativos al funcionamiento del Firewall se almacenan en el registro "Firewall". Si lo has habilitado previamente vuelve a deshabilitarlo.



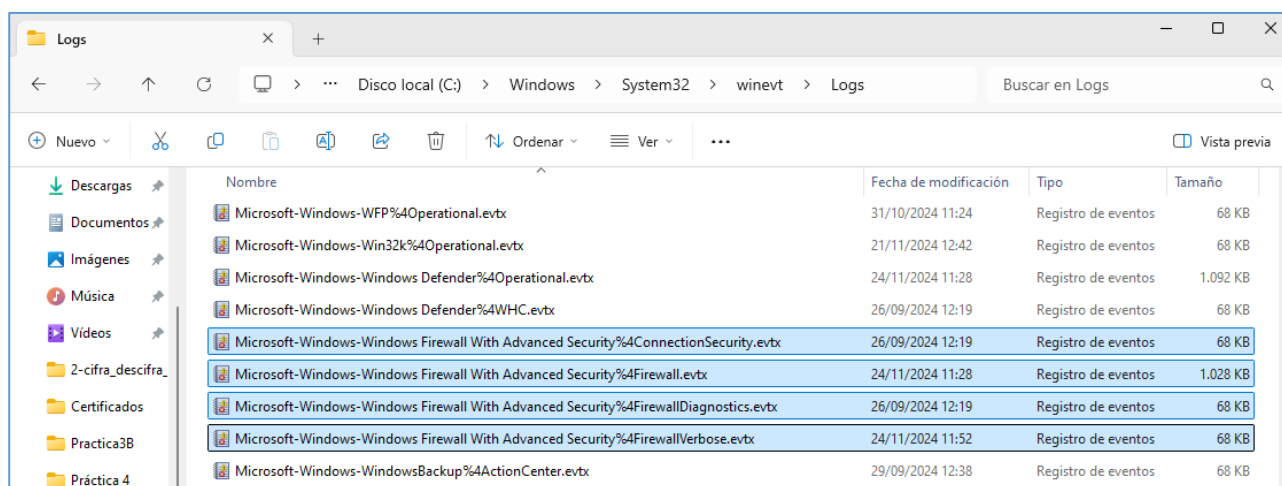
El registro "**Seguridad de conexión**" contiene los eventos relacionados con la configuración de las reglas y los parámetros de IPsec.

El registro "**Seguridad de conexión detallada**" contiene los eventos relacionados con el funcionamiento de IPsec.

Selecciona el registro "**Firewall**" en el panel izquierdo. En el panel derecho de acciones selecciona la opción "**Propiedades**" y aparece la ventana siguiente:



Observar el nombre del registro y su ubicación en el sistema de ficheros. Accede a esta ubicación para comprobar que efectivamente existen los ficheros de eventos mencionados.



Análisis de los eventos del registro

Utiliza el visor de eventos para ver los eventos del registro:

Registros de aplicaciones y servicios > Microsoft > Windows >
> Windows Firewall With Advanced Security / Firewall

Se puede comprobar que existen (o no si no se ha realizado la operación) estos eventos con los siguientes IDs:

ID	Descripción del evento
2003	Cambió una configuración de Firewall de Windows Defender en el perfil Público.
2006	Se eliminó una regla en la lista de excepciones de Firewall de Windows Defender.
2010	Cambió el perfil de red en una interfaz.
2033	Se eliminaron todas las reglas de la configuración de Firewall de Windows Defender en este equipo.
2051	Actualización de directiva de restricciones de inquilino.
2097	Se ha agregado una regla a la lista de excepciones del Firewall de Windows Defender.
2099	Se modificó una regla en la lista de excepciones de Firewall de Windows Defender.

La mayoría de los eventos están relacionados con las **reglas** del Firewall de Windows: agregación (2097), modificación (2097) o eliminación (2006, 2033).

Pero también se puede comprobar que el evento 2003 se utiliza para registrar una gran variedad de cambios en la configuración del Firewall.

6. Realización de ejercicios de auditoría

Los aspectos mostrados en esta práctica son solo un ejemplo introductorio de las posibilidades de auditoría disponibles en el sistema operativo Windows 11. Las posibilidades reales deben ser exploradas con más detalle por cada alumno realizando ejercicios personalizados de auditoría.

Los ejercicios deben realizarse en la **Máquina Virtual** utilizada en las prácticas y los pasos que se van realizando se deben documentar imprimiendo ventanas (Alt+ImprPant) y copiándolas en un documento, junto con un mínimo texto explicativo. Es muy conveniente guardar frecuentemente el documento en el formato "Documento XML abierto de Office (*.docx)".

Si se pide un ejercicio de auditoría en el examen de prácticas habrá que entregar un documento de este tipo en el Campus Virtual.

Generalmente, en los ejercicios de auditoría hay que realizar 4 tareas secuenciales:

1.-Activar y configurar los controles de seguridad.

Utilizar la herramienta **secpol**, el **Firewall**, o incluso **propiedades del sistema de ficheros**, como la concesión de permisos de acceso. Muchos de los controles que se pueden utilizar ya estarán activados y tendrán una configuración por defecto que aplica el propio sistema.

2.-Activar y configurar la auditoría de seguridad, para controlar los eventos que se generan.

El objetivo suele ser recopilar información sobre cuatro aspectos:

- Cuando se activa y se desactiva un control, por ejemplo el Firewall.
- Cuando se cambia la configuración de un control, por ejemplo las reglas del Firewall.
- Cuando el control detecta una violación de seguridad y cual, por ejemplo una denegación de acceso. Esto permite analizar los ataques que han fracasado.
- También se puede recabar información de la ausencia de violaciones de seguridad, por ejemplo todos los accesos que permite el Firewall. El volumen de información a tratar aumenta muchísimo. Pero esto permite analizar los ataques que han tenido éxito.

La herramienta fundamental para realizar esta tarea es **secpol**, usando la "Configuración de directiva de auditoría avanzada".

3.-Realizar pruebas para generar eventos.

En esta tarea los alumnos deben realizar algunas pruebas para generar eventos de auditoría. Por ejemplo, acceder al sistema dando contraseñas erróneas varias veces y finalmente volviendo a entrar con la contraseña correcta. También pueden acceder a archivos cuyo acceso este auditado. Y por supuesto, pueden intentar escanear el computador usando cualquier herramienta de red, como por ejemplo **Nmap** o **Nping**.

4.-Analizar los registros de eventos de seguridad, para evaluar problemas con la seguridad.

Utilizar el Visor de eventos para analizar los eventos capturados. Se puede vaciar el registro para tener unos pocos eventos y localizarlos rápidamente, pero **es más realista no hacerlo**. Diseñar algún filtro o alguna consulta para localizar algún tipo de evento en particular y documentarlo. Finalmente, volcar los archivos de eventos para su análisis, utilizando alguna herramienta de análisis de registros o realizando algún tipo de programa que procese eventos.